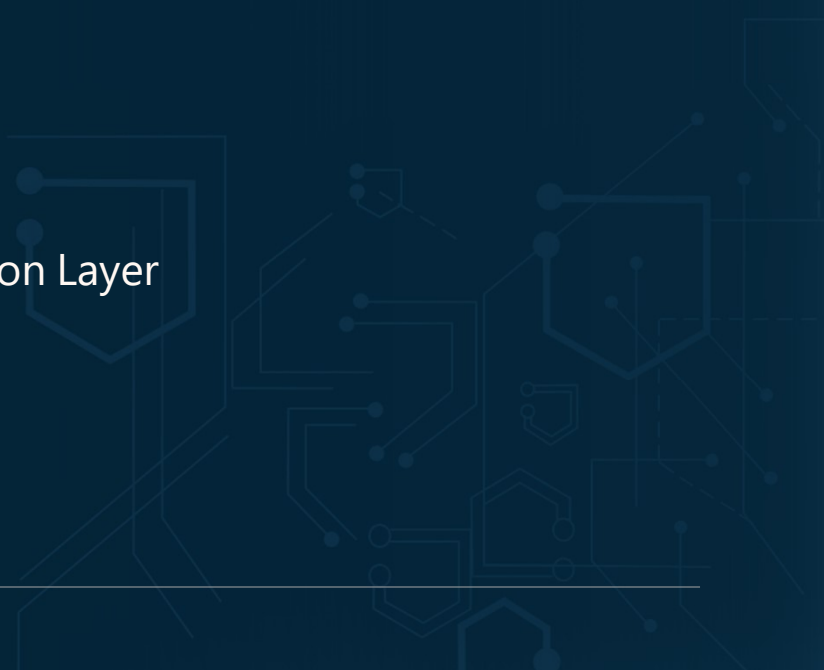
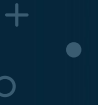
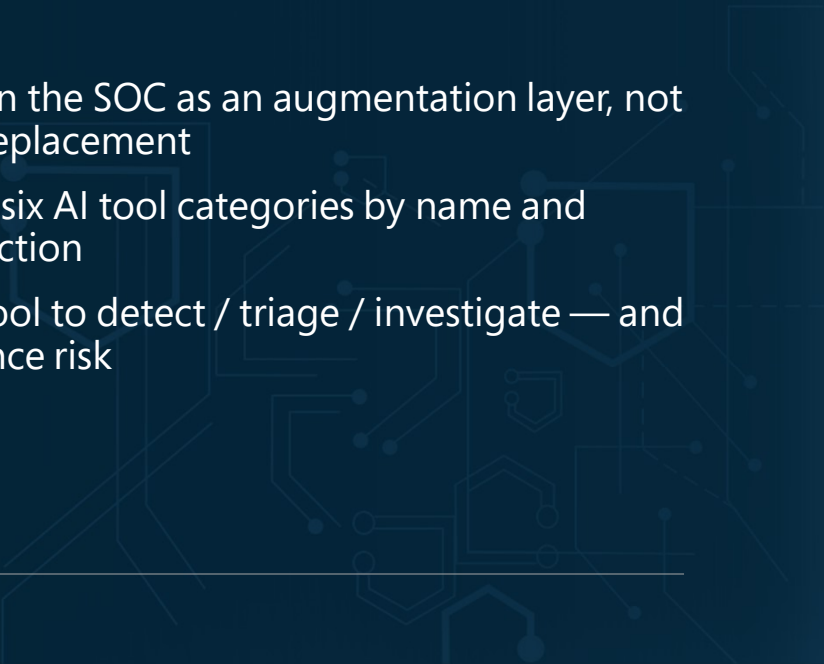
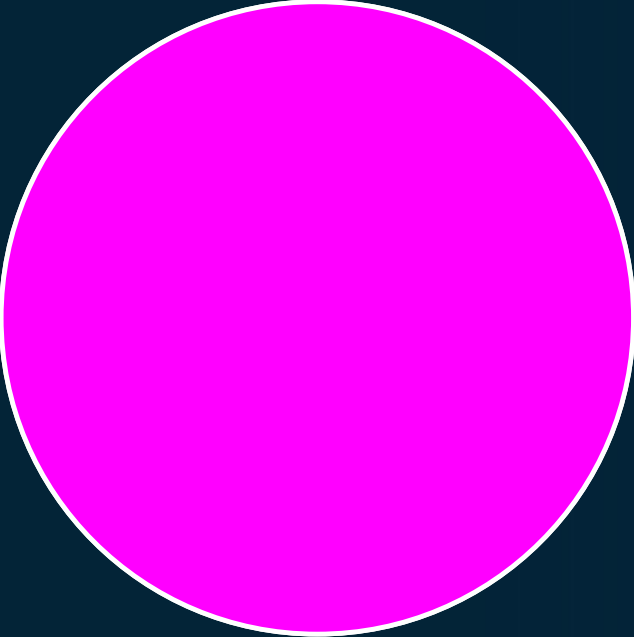


AI in the SOC

Chapter 10 · Episode 01 · Domain 3.1 — AI as an Augmentation Layer

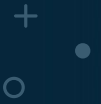




Learning Objectives

1. Position AI in the SOC as an augmentation layer, not an analyst replacement
2. Identify the six AI tool categories by name and primary function
3. Map each tool to detect / triage / investigate — and its governance risk

AI-Augmented Analyst Workflow



DETECTION

ML flags anomalies
Cuts dwell time

TRIAGE

Score & correlate alerts
Suppress low-fidelity noise

INVESTIGATION

Auto-enrich incidents
Threat intel in seconds

Six AI Tool Categories

CONVERSATIONAL / EMBEDDED

Chatbots & personal AI assistants

IDE plugins — secure coding

Browser plugins — threat context

PROGRAMMATIC

CLI plugins — log parsing

MCP servers — tool interfaces

Structured, auditable calls

Risks Each Tool Introduces



OVERRELIANCE

Treating AI as authoritative



DATA SENSITIVITY

Pasting incidents into cloud AI



AUTOMATION BIAS

Over-trusting
recommendations



MODEL QUALITY

Stale training underperforms

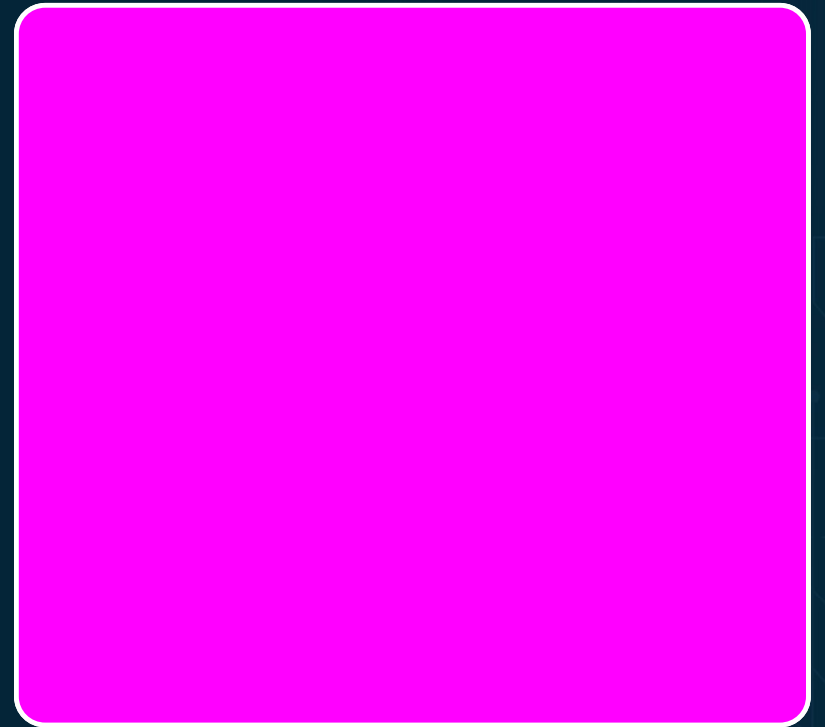
Human–AI Teaming in Practice

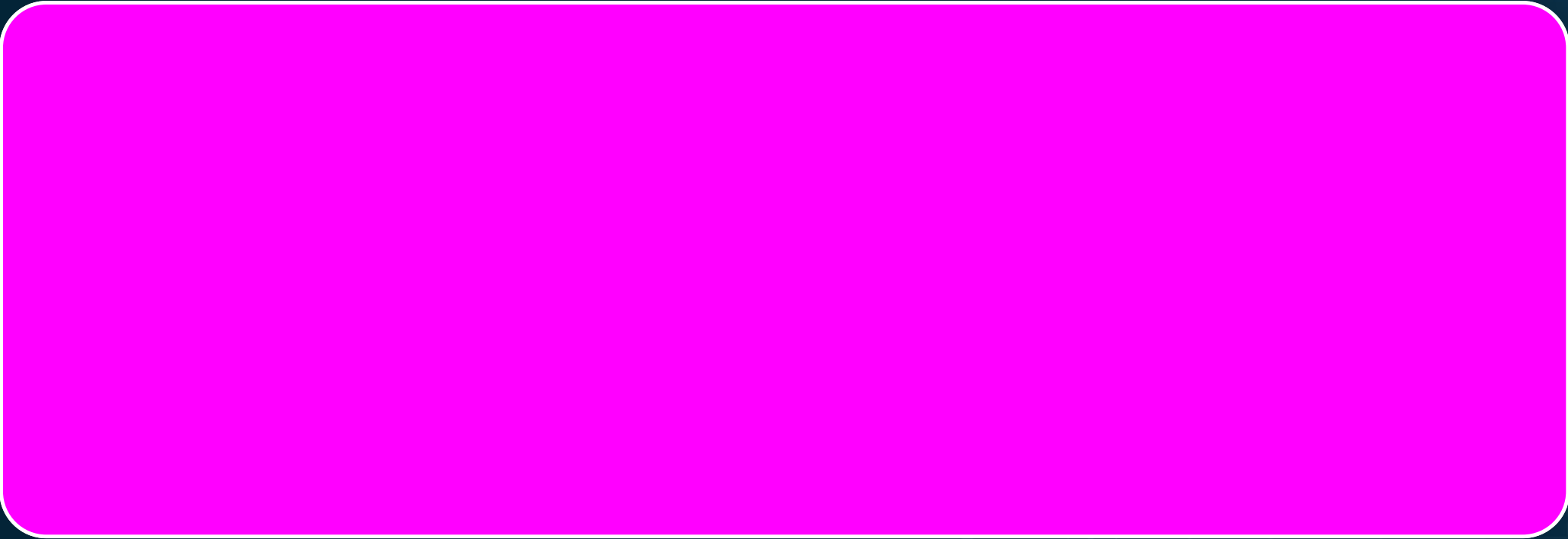
Analyst reviews top 5, not 50 raw alerts

AI drafts summary + response steps

Analyst validates, modifies, approves

AI = volume; human = judgment & accountability





Demo: AI SOC Analyst (GPT-4o mini)

Live alert triage, incident correlation & threat-intel summarization — with a human-review checkpoint (automation-bias risk)

Exam Tips



SIX TOOLS

Know each by name
& function



AUTOMATION BIAS

Key human-factors risk



3-STAGE FLOW

Detect, triage, investigate

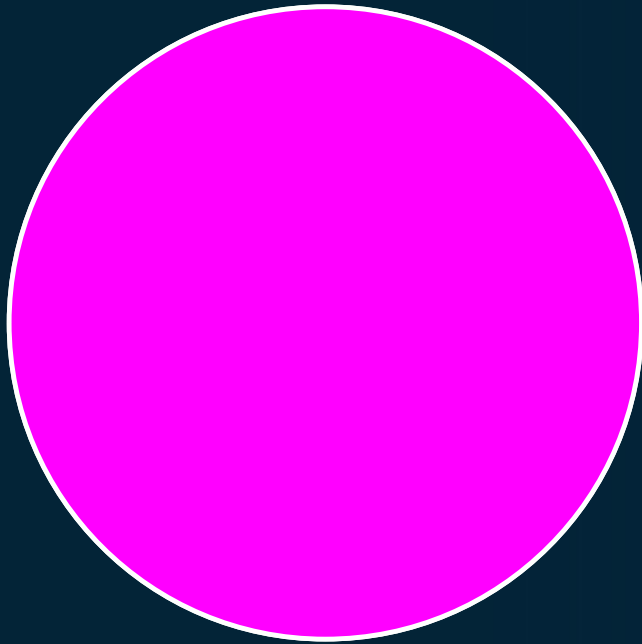


METRICS

AI cuts MTDD, MTTR, fatigue

IDE, Browser & CLI AI Plugins

Chapter 10 · Episode 02 · Domain 3.1 — AI Inside the Workflow



Learning Objectives

1. Match each plugin category to its primary function
2. Name the governance risk unique to each — code privacy, session access, privilege
3. Recognize MCP servers as the emerging integration layer

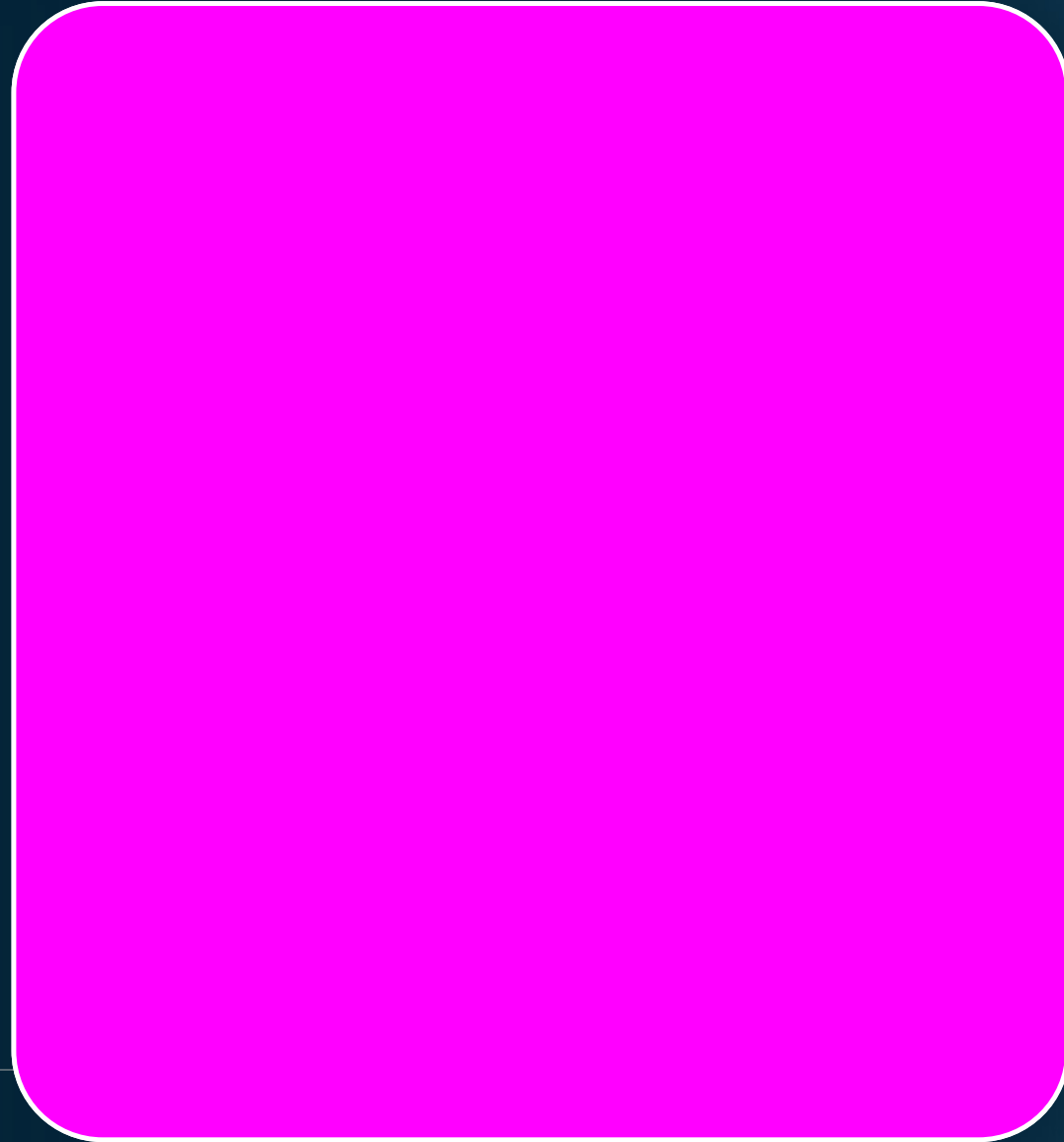
IDE Plugins — Shift Left

Real-time code analysis as you write

Flag SQLi, hardcoded creds,
unsafe deserialization

Secure autocomplete + linting

Risk: cloud code exposure & IP in training



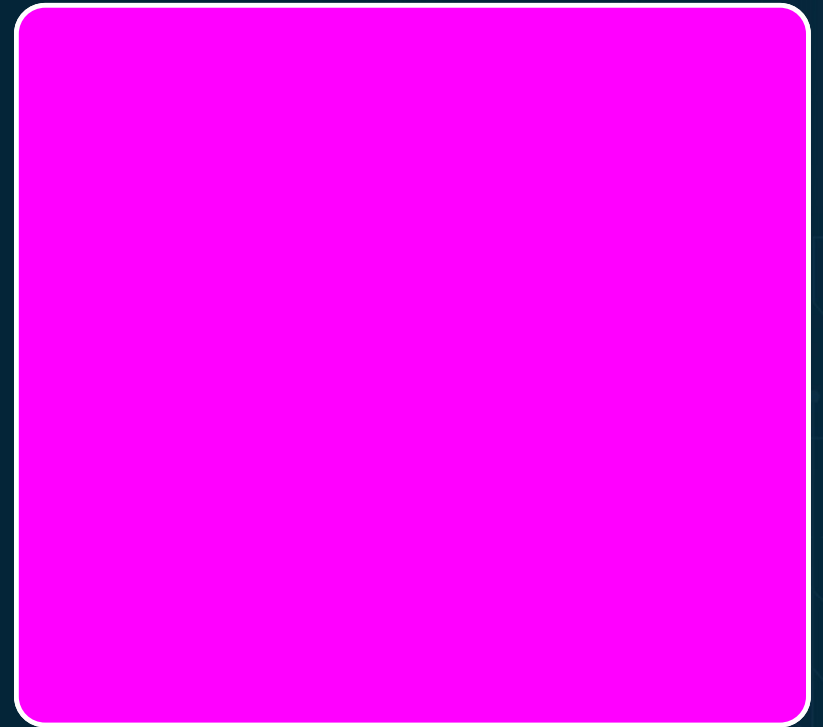
Browser Plugins — Threat Context

Inline reputation, WHOIS, actor data

Safe-browsing: block malicious URLs

Signature-match malicious JavaScript

Risk: access to authenticated sessions



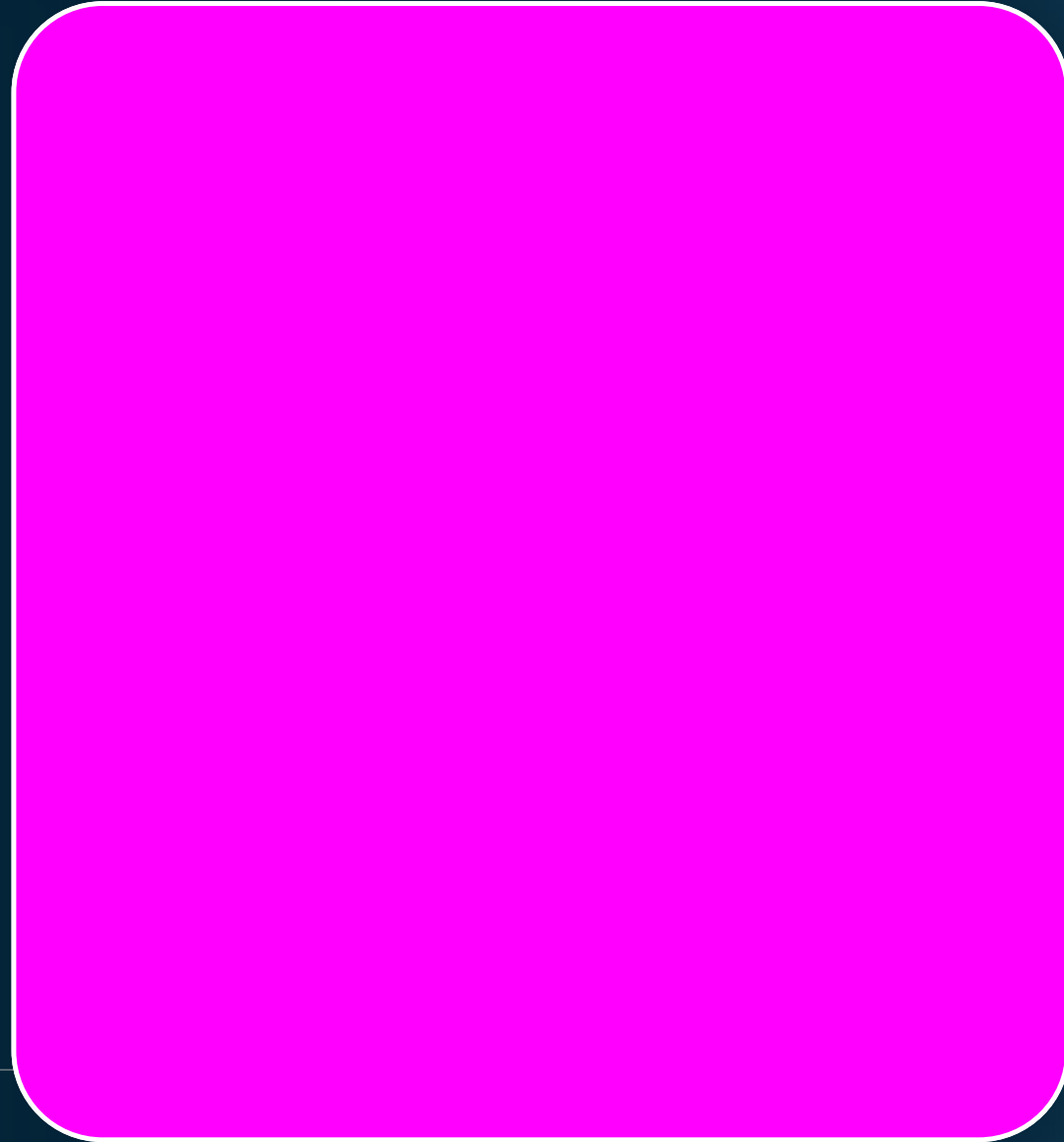
CLI Plugins — Automate the Terminal

Log parsing → structured summaries

Natural language → command translation

Hash/IOC matching in-terminal

Risk: elevated perms → integrity checks



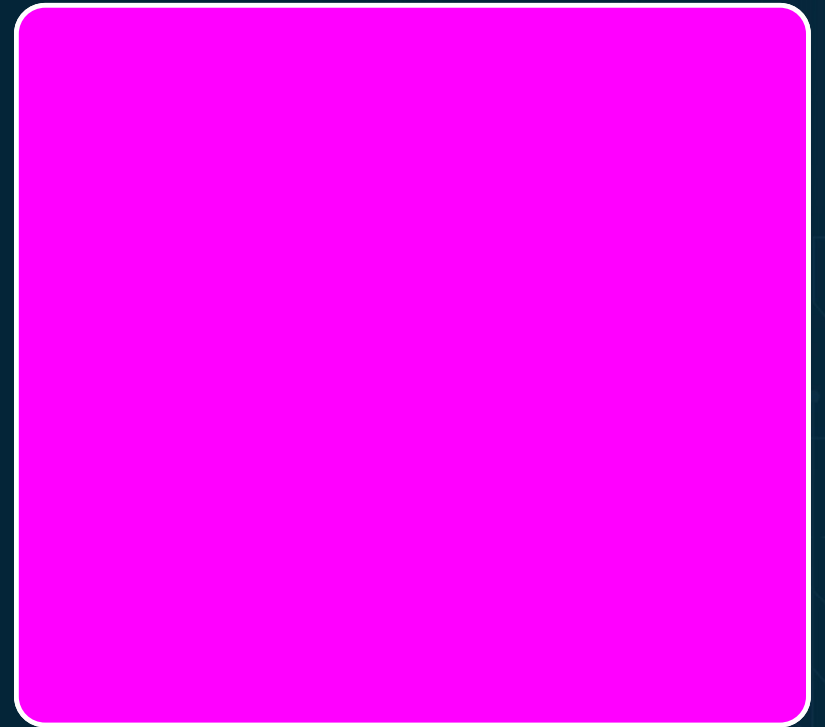
MCP Servers — the Integration Layer

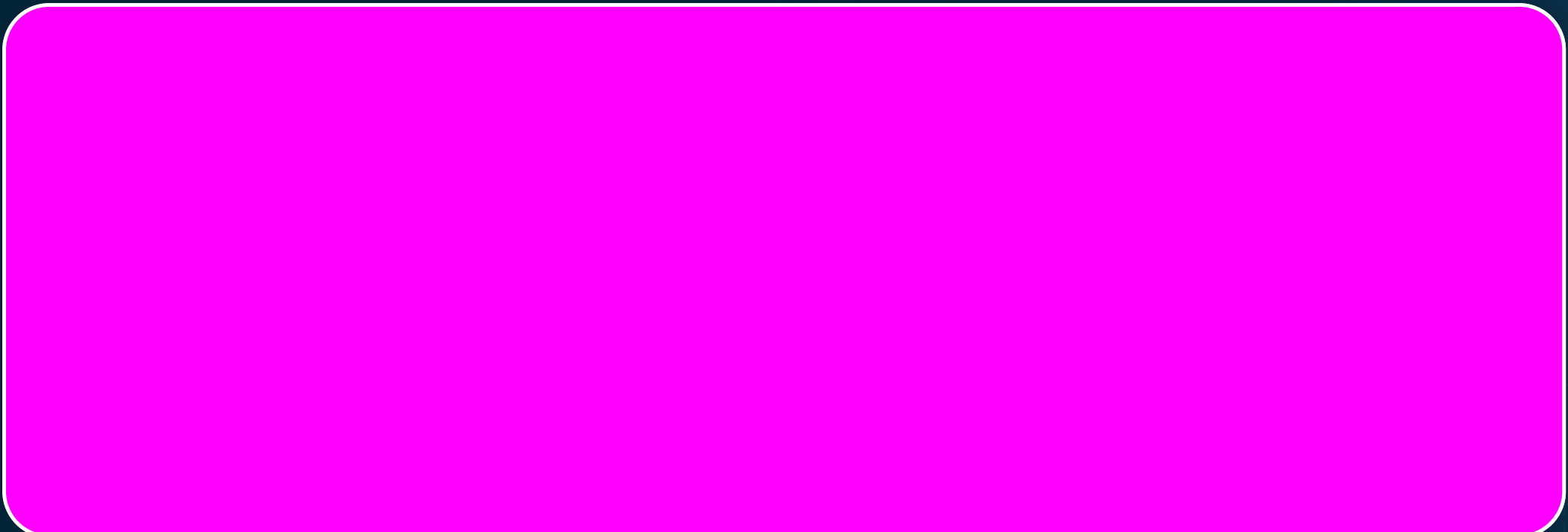
Expose tools as callable functions

Agents query SIEM, create tickets, escalate

Structured, auditable API calls

High-value target → authN / authZ / audit





Demo: Three Plugin Categories + MCP

IDE vuln scanning, browser threat enrichment, CLI log parsing & MCP-server governance audit

Exam Tips



IDE

Secure coding at the source



CLI

High-privilege automation



BROWSER

Threat context +
safe browsing

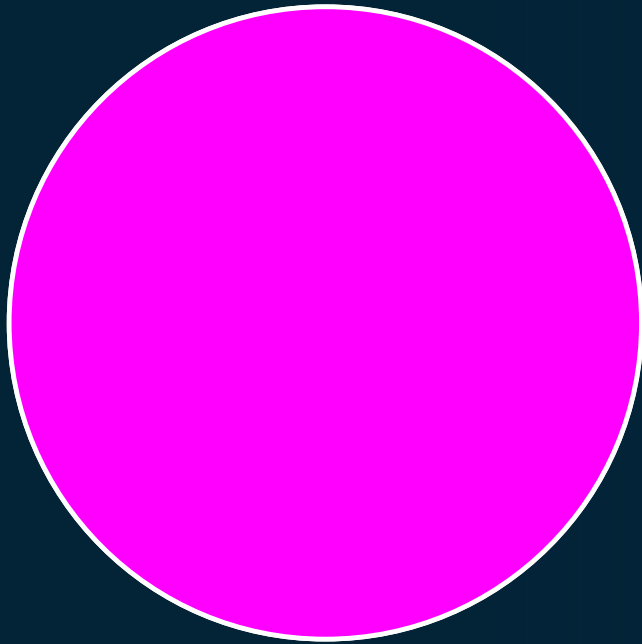


MCP SERVERS

AuthN, authZ, audit every call

AI for Vulnerability Analysis

Chapter 10 · Episode 03 · Domain 3.1 — Discover, Classify, Prioritize at Scale



Learning Objectives

1. Explain the three AI capabilities: pattern recognition, anomaly detection, prioritization
2. Distinguish static vs dynamic analysis — both AI-enhanced
3. Enrich CVSS with context rather than replace it

Three AI Capabilities

PATTERN RECOG

Structural vuln signatures

Static + dynamic

ANOMALY

Deviation from baseline

No signature needed

PRIORITIZATION

Risk-adjusted ranking

Context over raw CVSS

Static vs Dynamic Analysis

STATIC

Review code / binaries

No execution

Buffer overflow, injection sinks

DYNAMIC

Monitor running apps

Unexpected calls & syscalls

Behavioral deviation

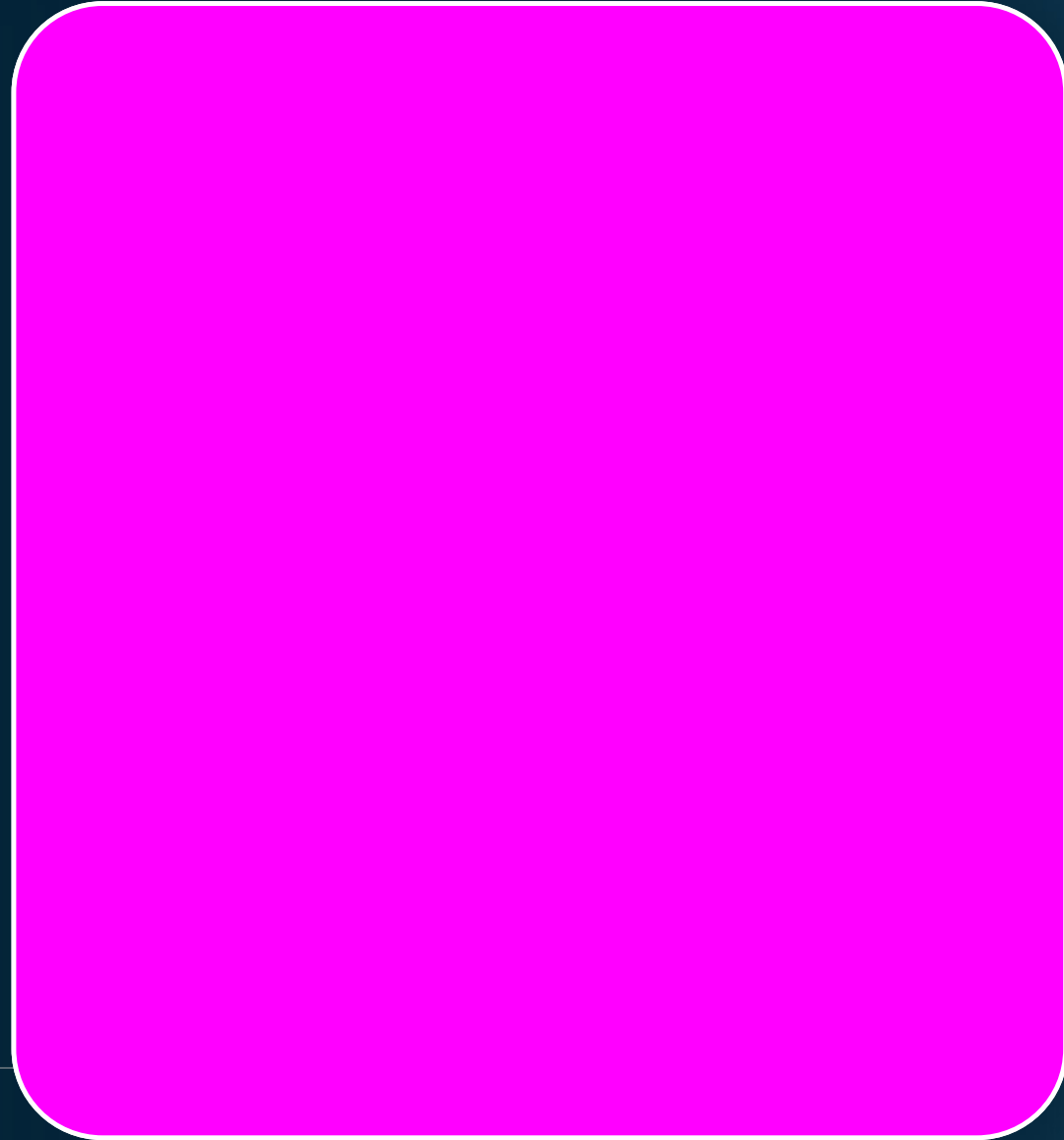
Anomaly Detection — Zero-Day Edge

No known signature required

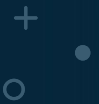
Effective vs zero-day & novel evasion

Trade-off: higher false-positive rate

AI calibrates with context & history



Prioritization: Multi-Dimensional



CVSS BASE
Starting score



ASSET VALUE
Business criticality



EXPLOITED?
Active in the wild



EXPOSURE
Internet-facing + intel

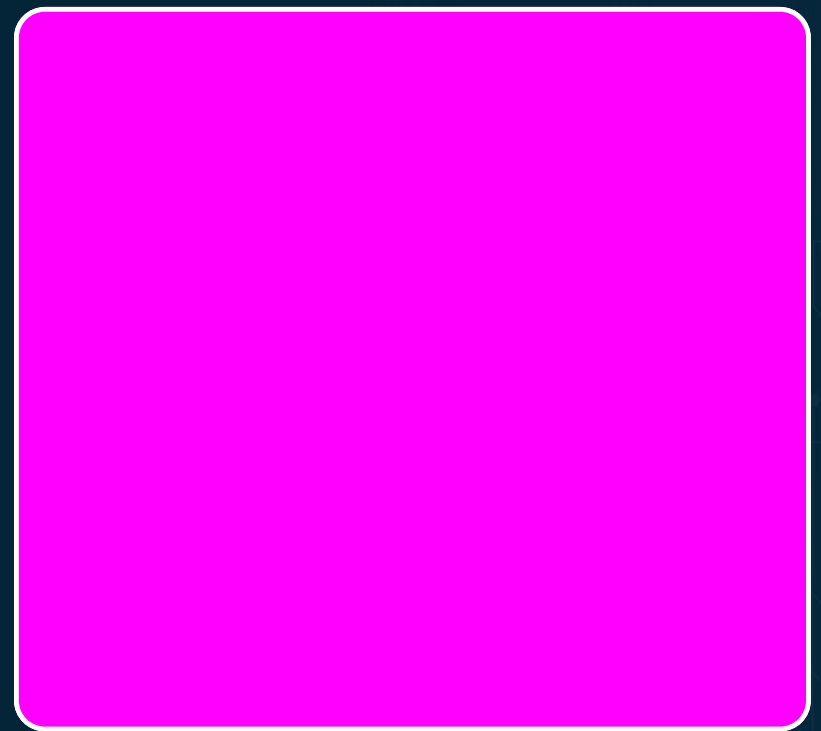
Governance Requirements

Update models — data currency

Human validation of findings

Integrate asset inventory

Stale model → misses current threats



Demo: AI Vulnerability Analysis

Static pattern detection, behavioral anomaly scoring & risk-adjusted CVE prioritization (CVSS + exploitability + criticality + exposure)

Exam Tips

3 CAPABILITIES

Pattern, anomaly, priority

STATIC vs DYNAMIC

Code review vs runtime

ANOMALY EDGE

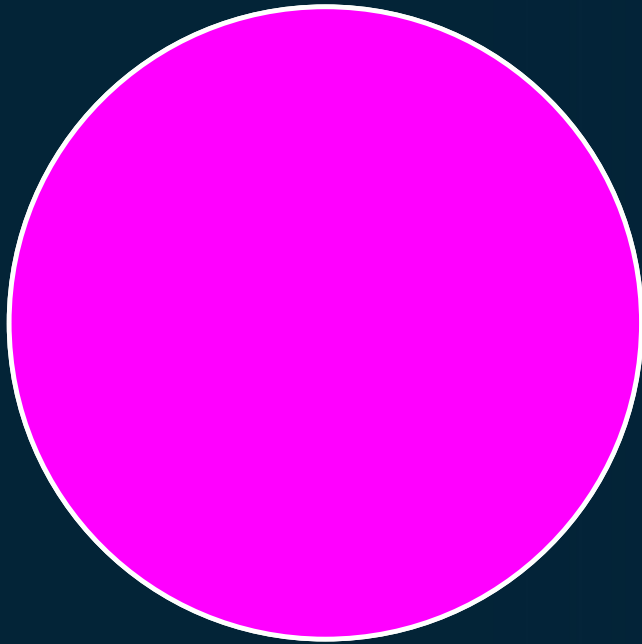
Zero-day, higher FP rate

ENRICH CVSS

Context-aware ranking

Automated Penetration Testing

Chapter 10 · Episode 04 · Domain 3.1 — Continuous Automated Red Teaming



Learning Objectives

1. Frame automated pen testing as continuous, scope-defined offensive assessment (CART)
2. Walk the phases: recon → exploit discovery → chaining → red/purple teaming
3. Treat explicit scope authorization as the non-negotiable control

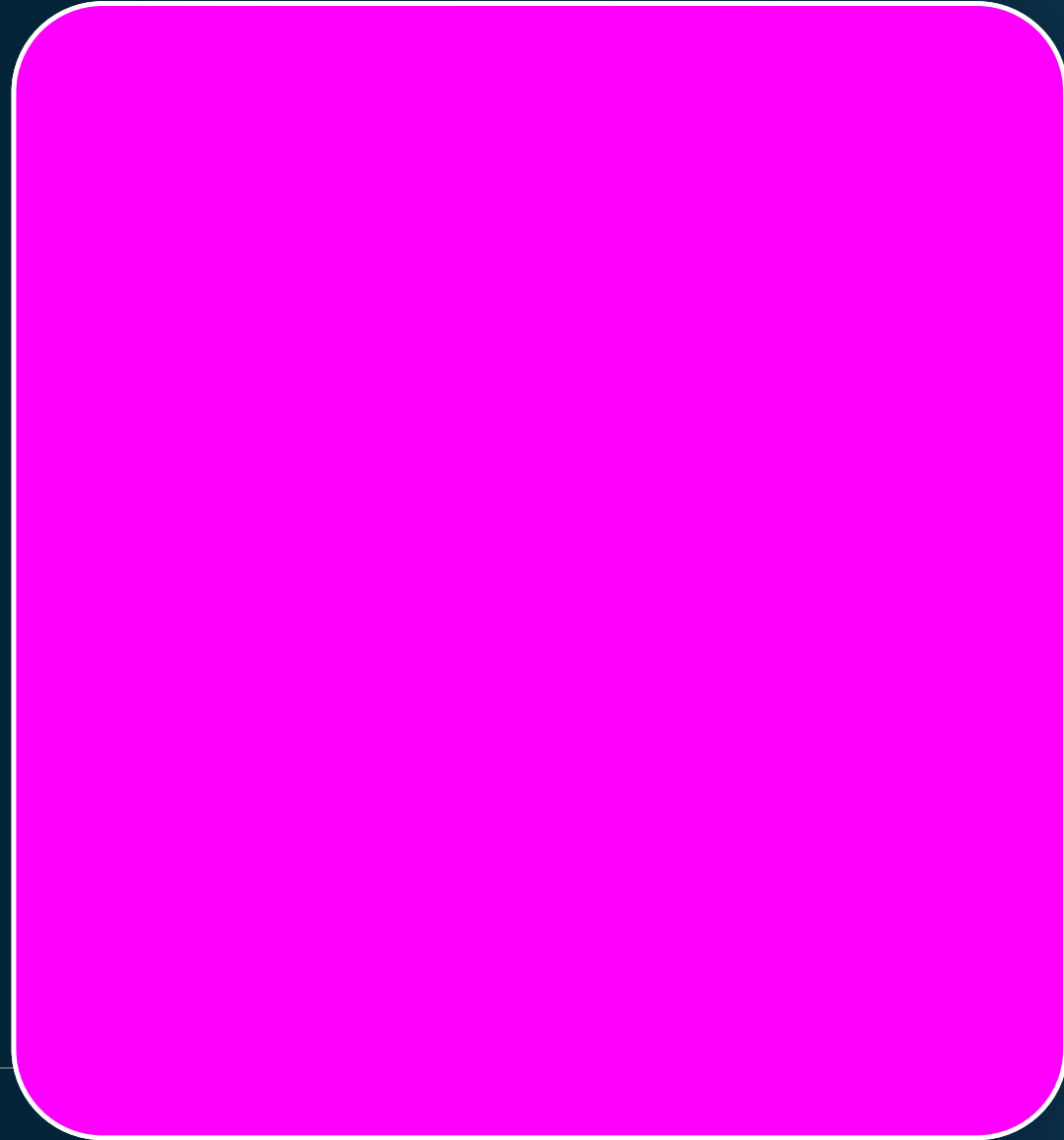
AI-Assisted Reconnaissance

Enumerate services, subdomains, topology

OSINT: DNS, cert logs, GitHub leaks

Job postings + social for stack/roles

Same map serves attackers AND defenders



Exploit Discovery & Chaining



DISCOVERY

Match known patterns
Pre-approved exploits

FUZZING

Learns input structure
Intelligent mutations

CHAINING

Low-sev → high-sev path
Multi-step logic



Red & Purple Teaming

AI HANDLES

Volume scanning

Auth endpoint testing

Network path mapping

HUMANS HANDLE

Creativity & adversarial reasoning

Novel attack chains

Social engineering

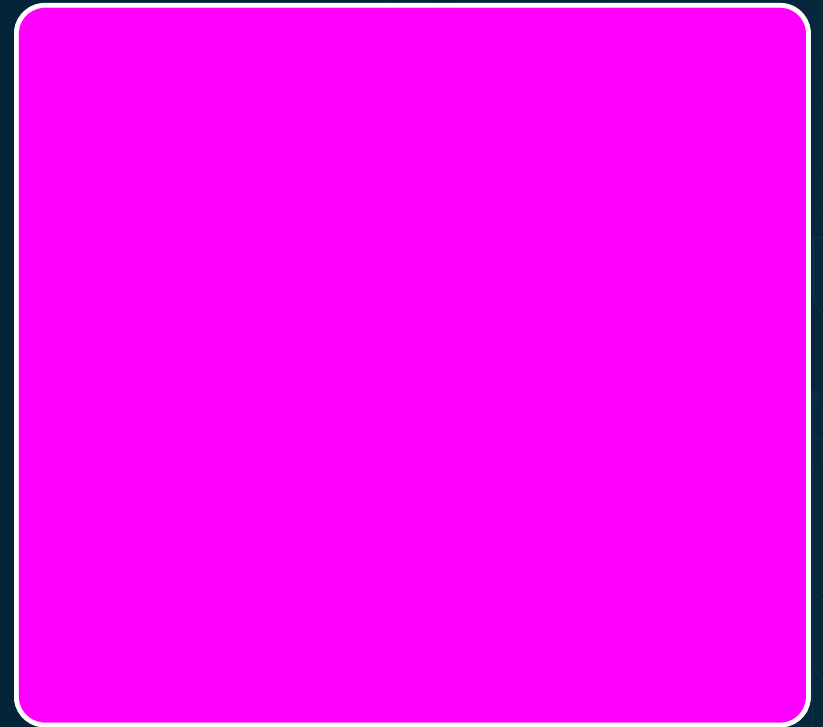
Governance: Authorization First

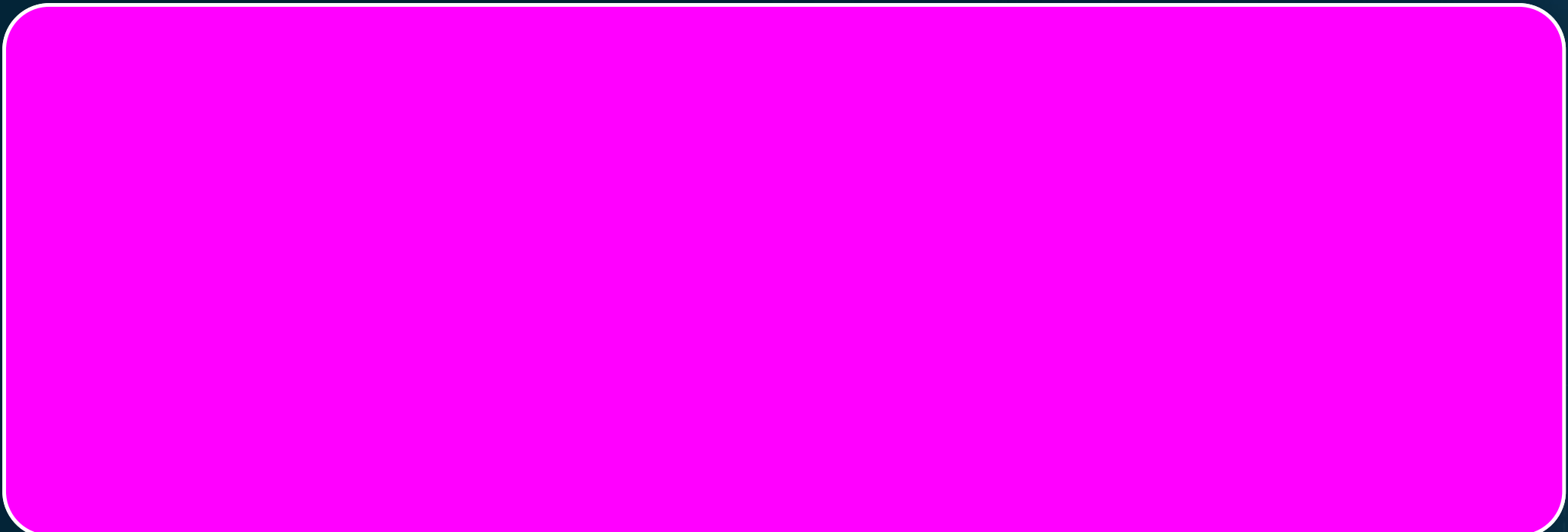
Explicit, documented scope

Safe harbor + rules of engagement

Time-limited, scoped credentials

Structured findings → validated remediation





Demo: AI-Assisted Recon & Testing

OSINT aggregation, attack-surface mapping, intelligent fuzzing, exploit chaining & governance authorization checks

Exam Tips



SAME TECHNIQUES

Defensive = offensive



SMART FUZZING

Context-aware inputs



RECON = OSINT

DNS, certs, GitHub, social



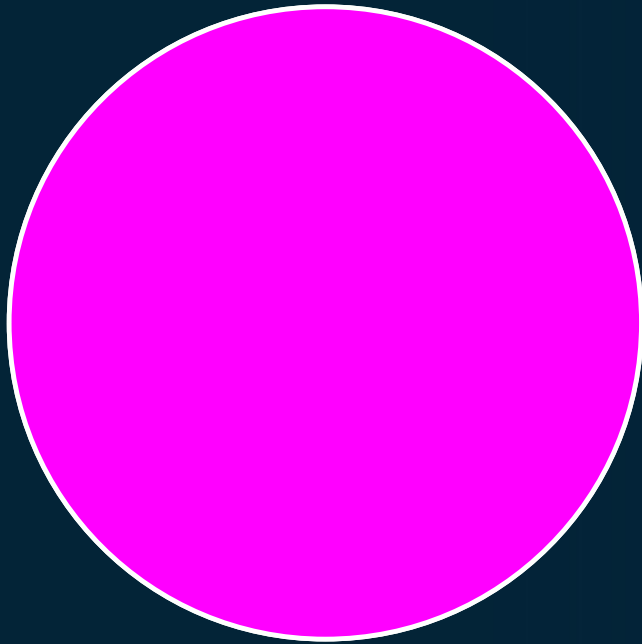
GOVERNANCE

Scope + RoE + creds + findings

A decorative circuit pattern in a light blue color, featuring various geometric shapes like hexagons, squares, and lines, resembling a network or data flow diagram, located in the bottom right corner of the slide.A set of small, light blue decorative icons in the top right corner, including a plus sign, a circle, and a dot.

Incident Management & Ticket Automation

Chapter 10 · Episode 05 · Domain 3.1 — From Raw Alerts to Tracked Incidents



Learning Objectives

1. Show how AI closes documentation gaps by generating records from telemetry
2. Connect SOAR + AI = dynamic playbook selection and automated response
3. Keep human approval on high-impact response actions

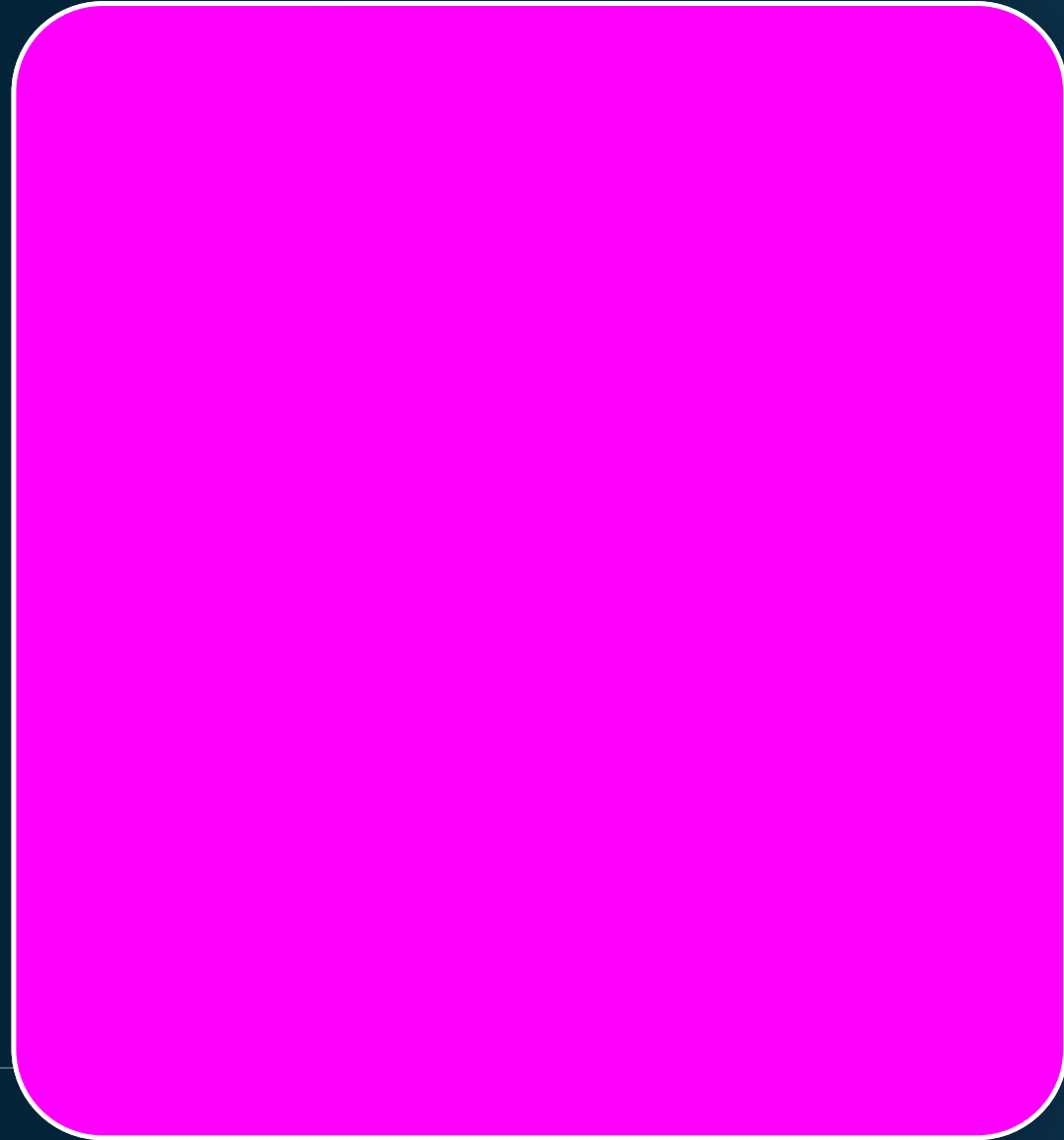
Summaries & Correlation

Auto-draft: event, assets, classification, evidence

Technical + executive readable

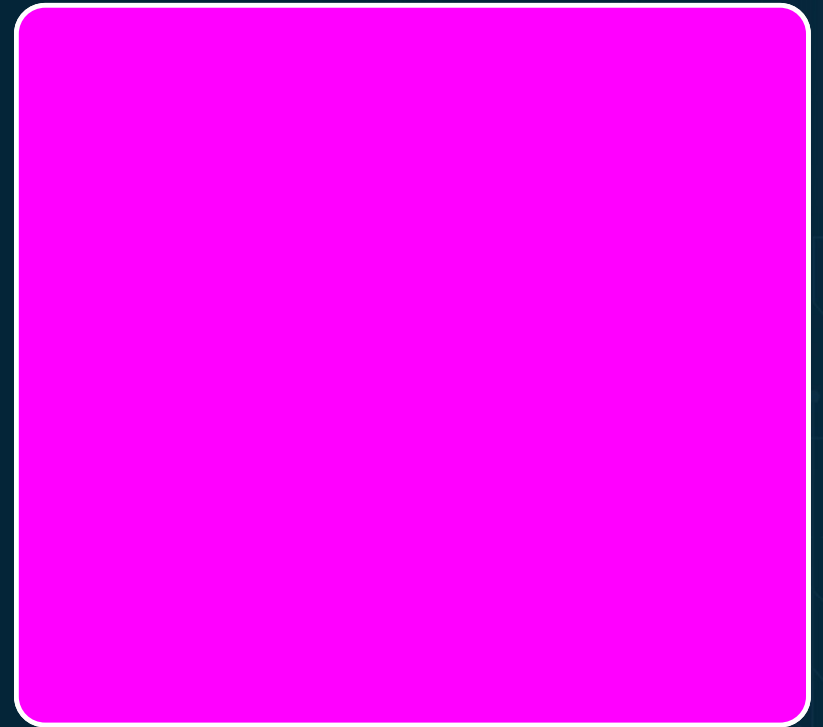
Correlate related alerts → one incident

Starts the record for review & legal



SOAR + AI = Dynamic Response

AI classifies incident → selects playbook
Isolate endpoint, block IP, revoke cred
Route to right tier/team by type
Escalate on threshold + SLA tracking



Human Oversight on Response

AUTONOMOUS OK

Enrichment & summaries

Routing & prioritization

Low-impact steps

APPROVAL REQUIRED

Credential revocation

Endpoint isolation

High-impact actions

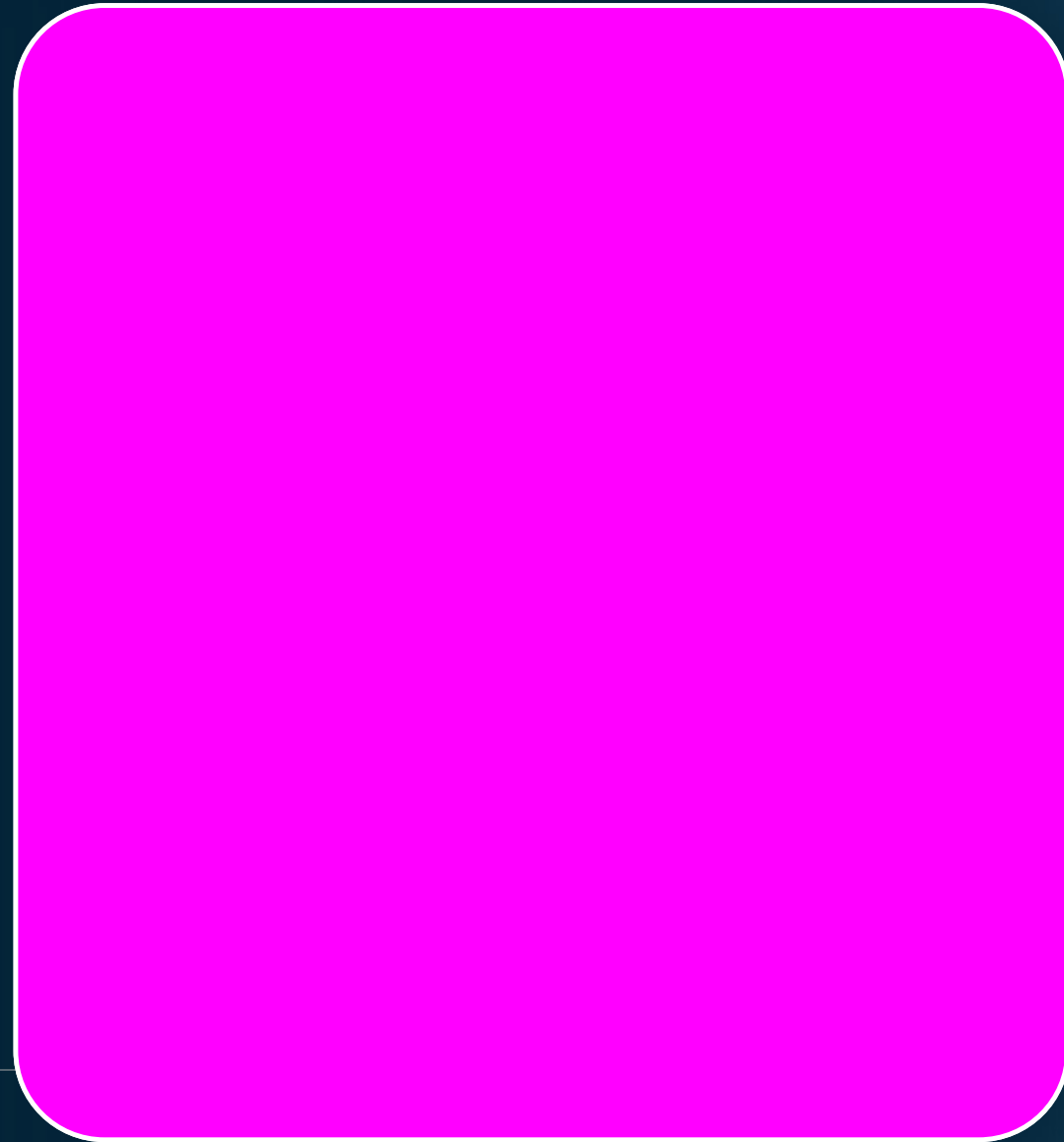
Post-Incident Analysis

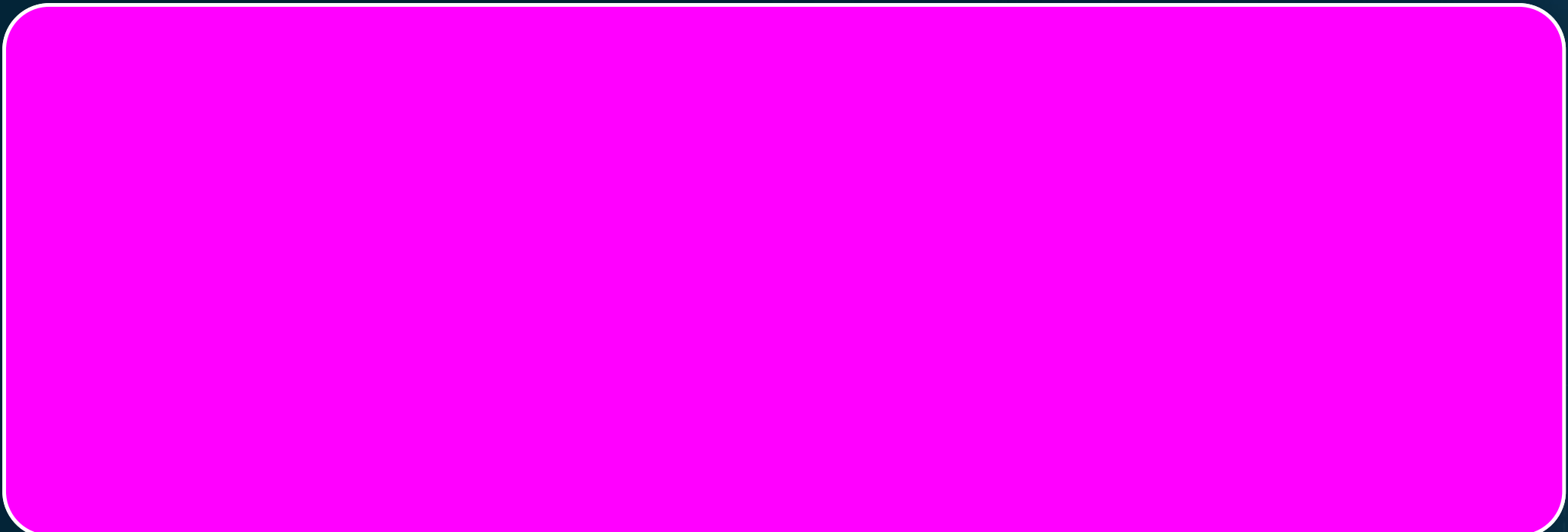
Analyze full timeline & latencies

Find response bottlenecks & gaps

Pattern analysis across incidents

Feeds continuous program improvement





Demo: AI Incident-Management Pipeline

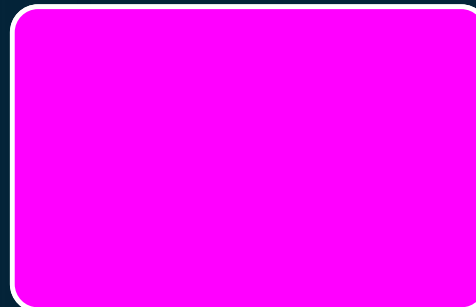
GPT-4o mini generates summaries, selects SOAR playbooks, drafts stakeholder notices & produces post-incident reports

Exam Tips



THREE PROBLEMS

Docs, correlation, MTTR



HUMAN-IN-LOOP

Approve high-impact steps



SOAR + AI

Dynamic playbook selection

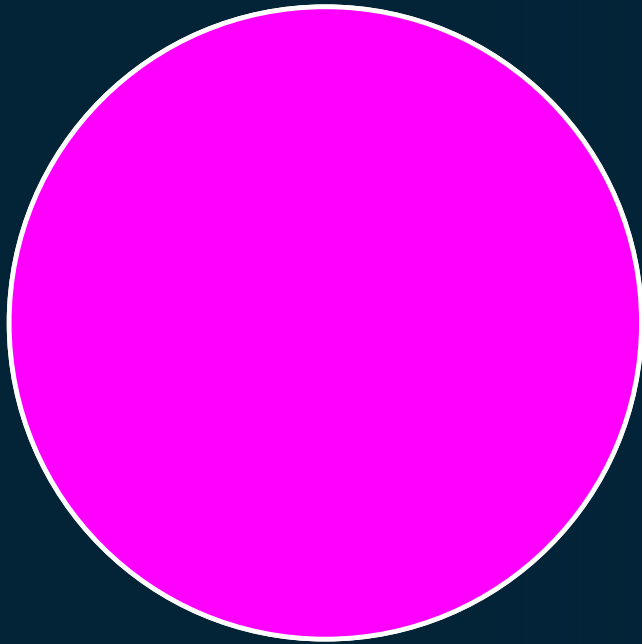


POST-INCIDENT

Feedback → improvement

Fraud Detection & Pattern Recognition

Chapter 10 · Episode 06 · Domain 3.1 — ML's Most Mature Security Application



Learning Objectives

1. Explain why fraud is ML's most mature security use case
2. Match the three techniques: supervised classification, anomaly detection, graph analysis
3. Connect behavioral biometrics to continuous authentication

Three ML Techniques

SUPERVISED

Labeled fraud/legit
Classify new txns

ANOMALY

Baseline deviation
Unusual merchant/geo/time

GRAPH

Relationship mapping
Detect fraud rings

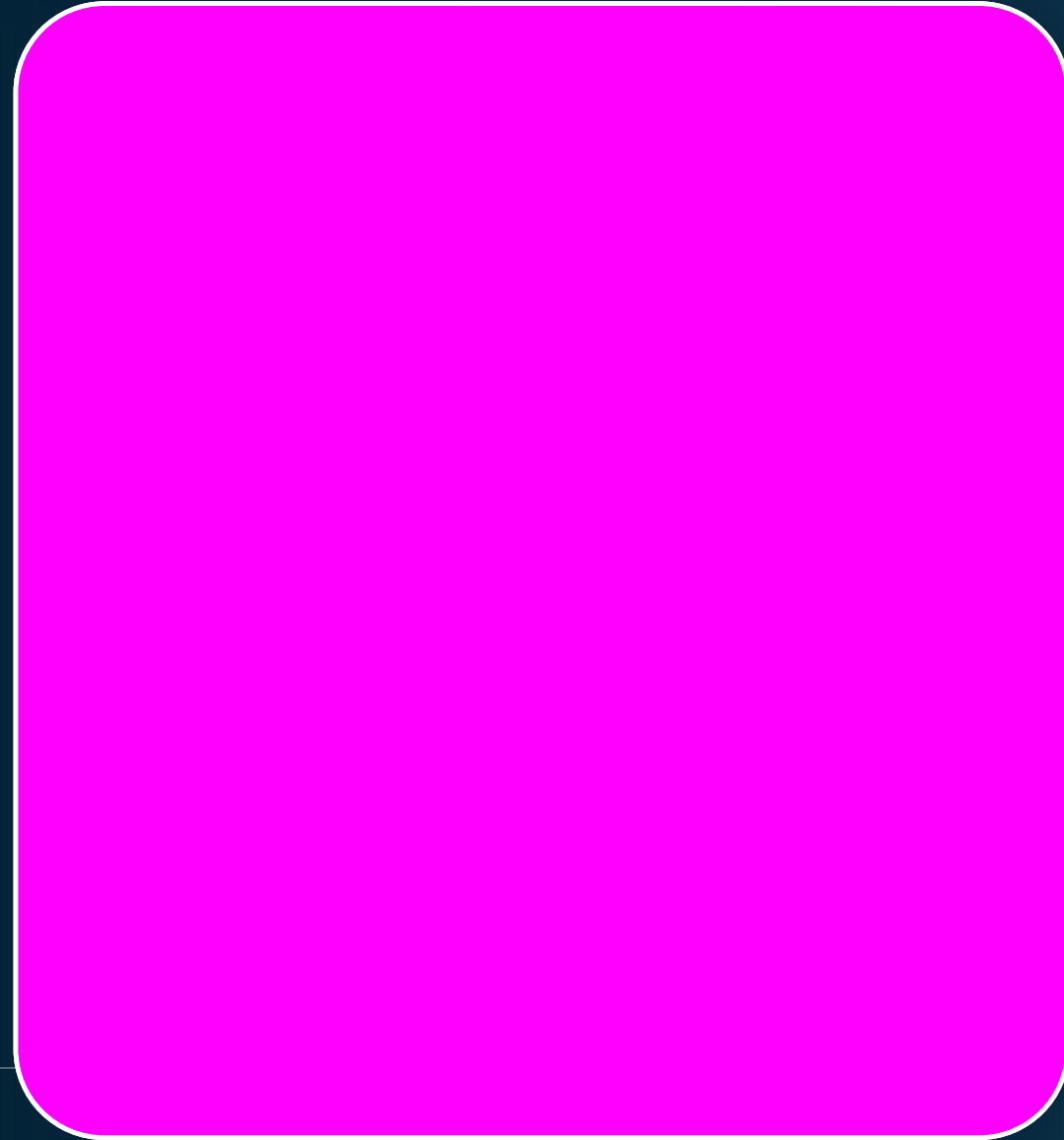
Behavioral Biometrics

Typing rhythm, mouse, touch pressure

A signature unique to the user

Flags valid creds + wrong behavior

Enables continuous authentication



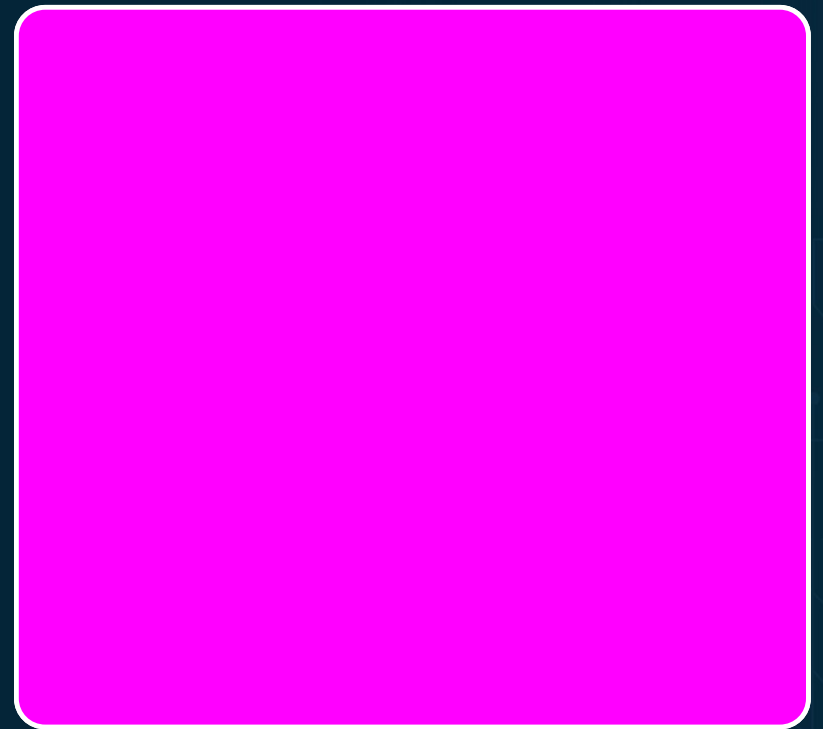
Real-Time Fraud Scoring

Score every txn before authorization

Sub-second latency at massive scale

100–200 ms per decision

Explainability = regulatory requirement



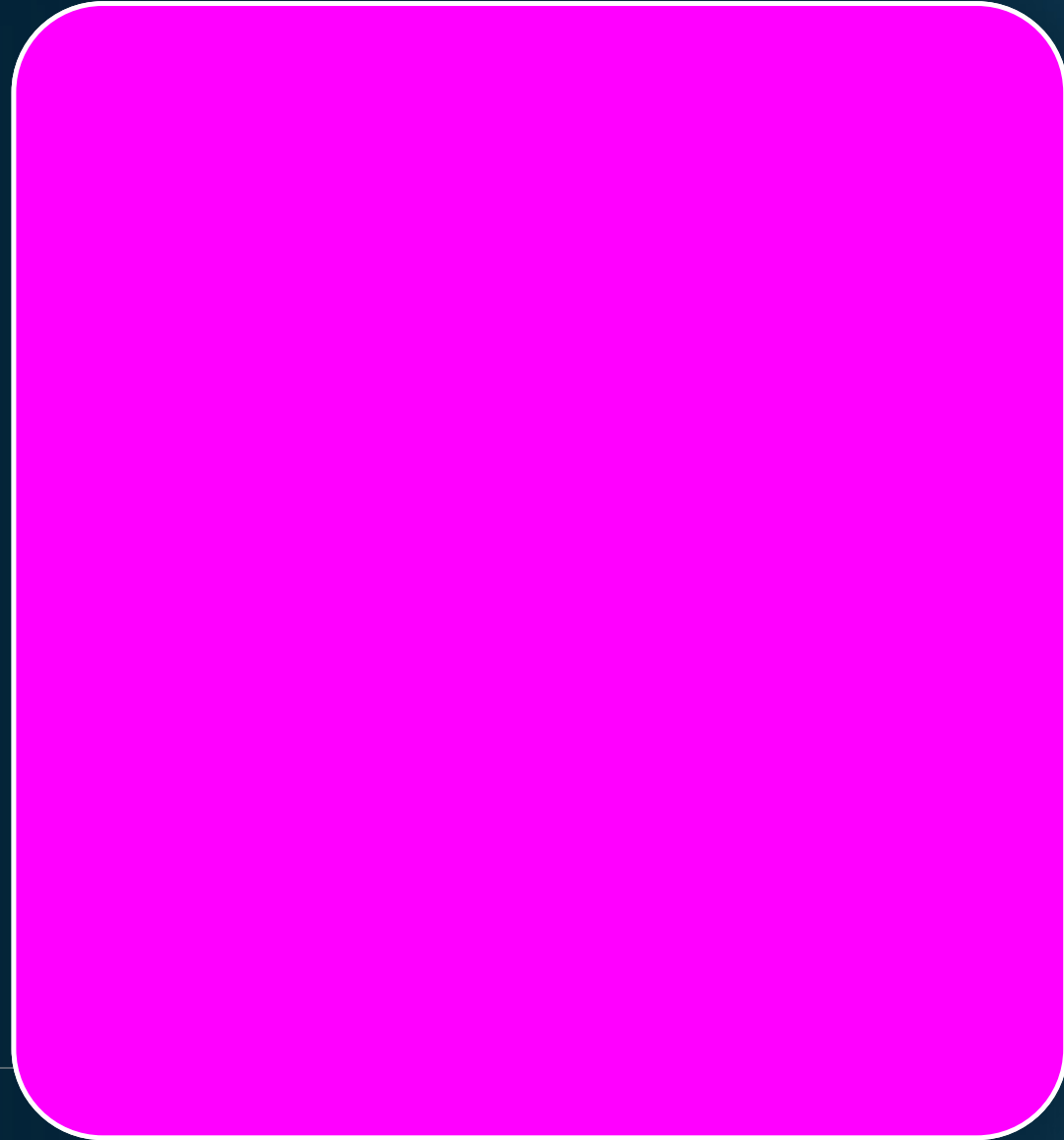
An Adversarial Arms Race

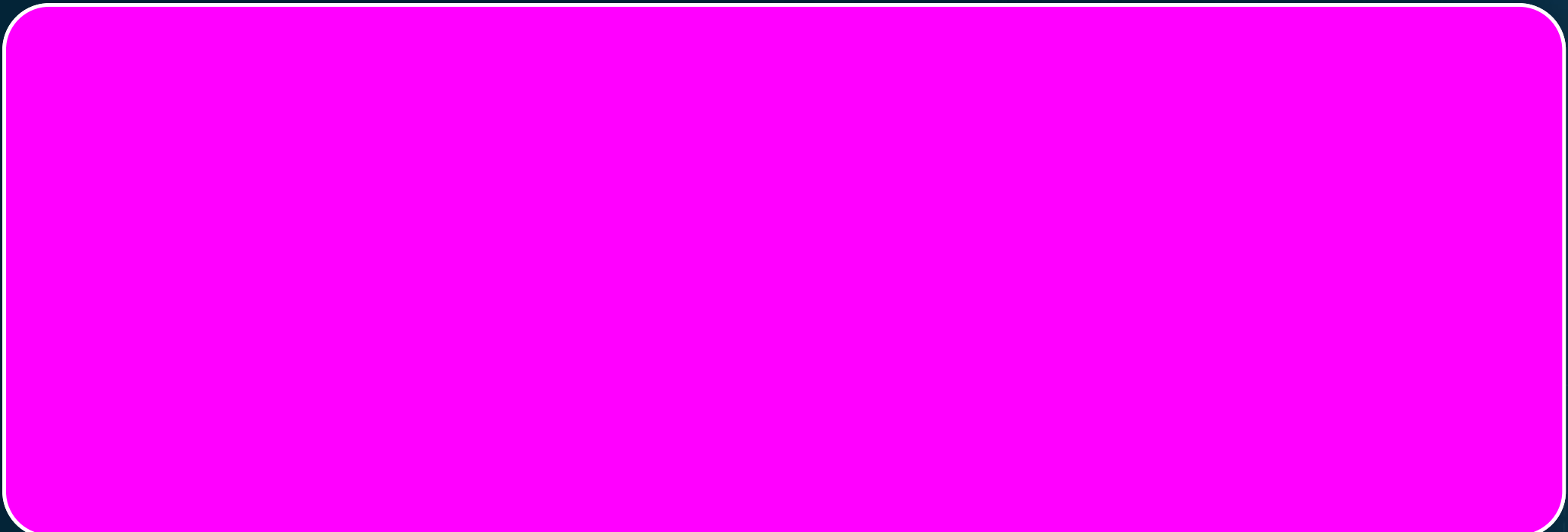
Structuring: split below thresholds

Mimic legitimate behavior

Continuous retraining required

Federated learning preserves privacy





Demo: Fraud Detection Techniques

Supervised classification, anomaly detection, graph analysis + real-time risk scoring & behavioral biometrics

Exam Tips



3 TECHNIQUES

Supervised, anomaly, graph



REAL-TIME

Sub-second + explainable



BIOMETRICS

Continuous authentication

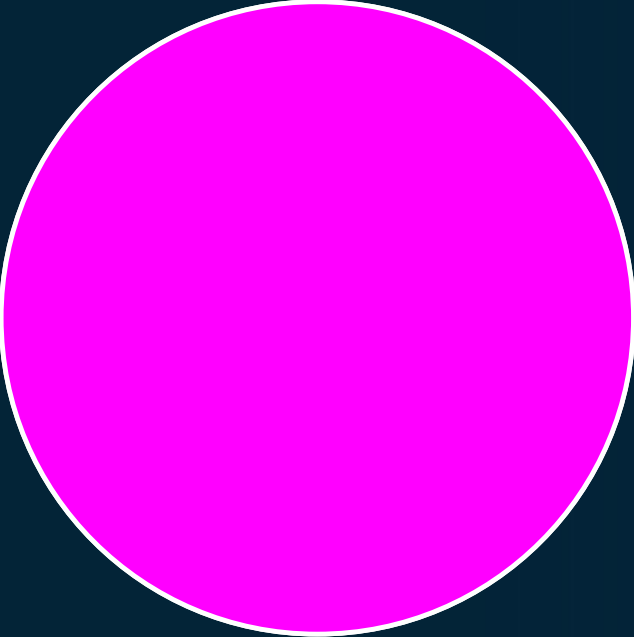


ARMS RACE

Retrain or degrade

AI-Assisted Translation & Summarization

Chapter 10 · Episode 07 · Domain 3.1 — Productivity with Data-Handling Risk



Learning Objectives

1. Name the security use cases for AI translation and summarization
2. Treat submitting sensitive content to cloud AI as a governed data-handling event
3. Flag prompt injection through submitted documents as a distinct vector

Translation Use Cases

MALWARE DOCS

Foreign analysis reports
Exploit-kit docs

THREAT INTEL

Dark-web forums
State-actor comms

PHISHING

Multilingual lures
Targeting logic

Summarization Use Cases

THREAT INTEL

200-page APT → minutes

Actionable briefings

INCIDENT DATA

Logs → narrative

Post-incident reviews

EXEC BRIEFING

Tech → business language

CISO / board / legal

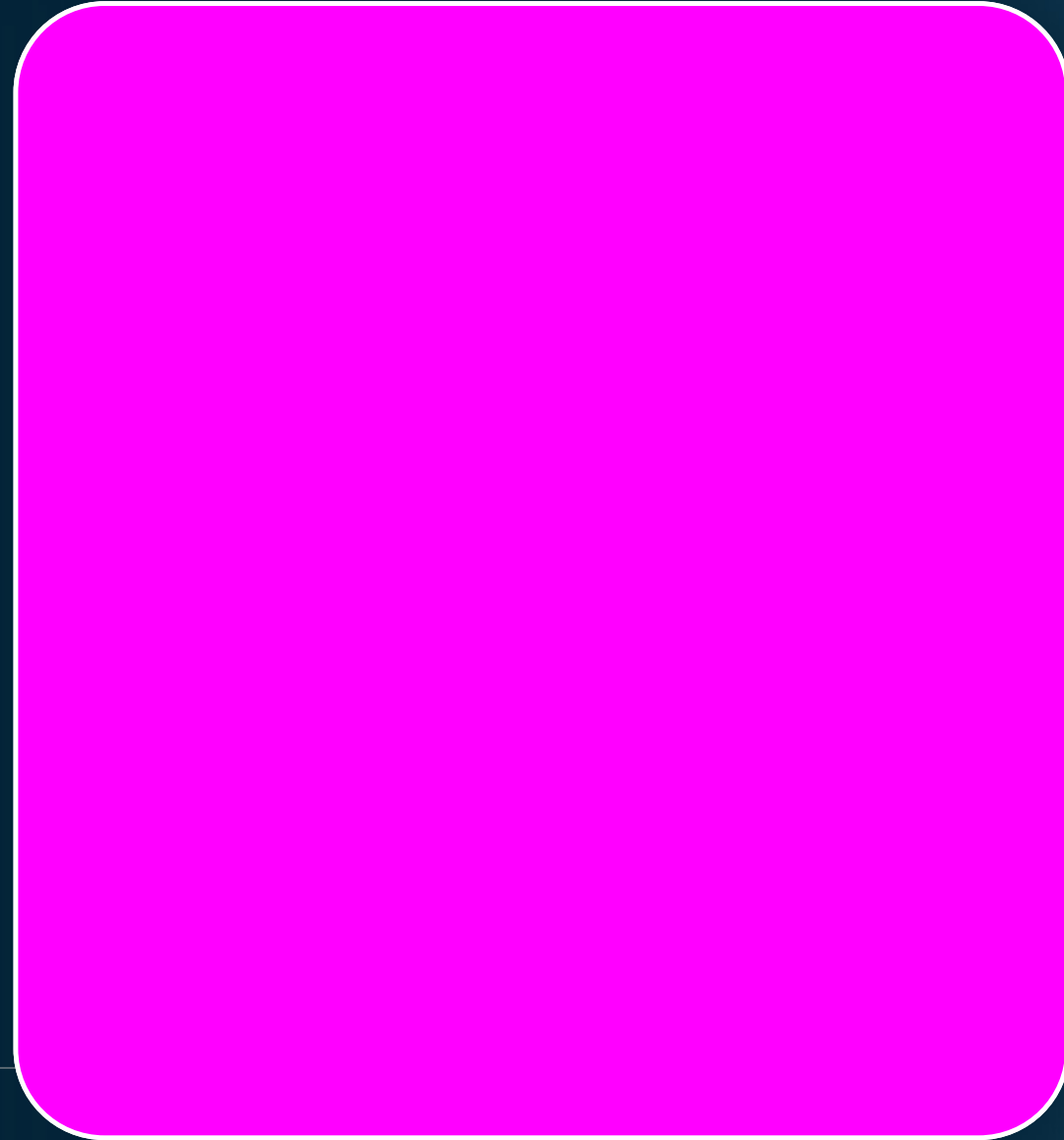
Data-Handling Risks

Cloud paste → vendor retention & training

Cross-jurisdiction data residency

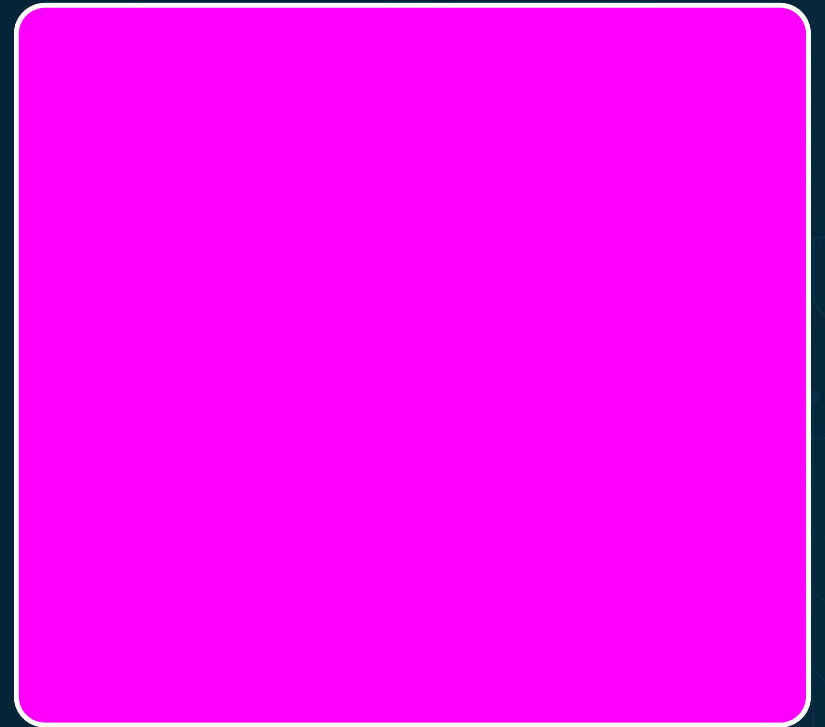
Indefinite logging in AI infra

Submitting sensitive content =
governed event



Prompt Injection via Documents

Malicious docs hide instructions
Injection targets the AI on submission
Hallucination in technical summaries
Validate high-stakes output vs source



Demo: Translation & Summarization

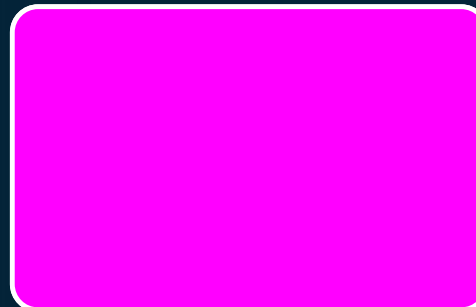
Classify before submission, prompt-injection scan on documents, simulated AI outputs & governance audit

Exam Tips



USE CASES

3 translation, 3 summarization



PROMPT INJECTION

Via submitted documents



DATA HANDLING

Cloud paste = exposure

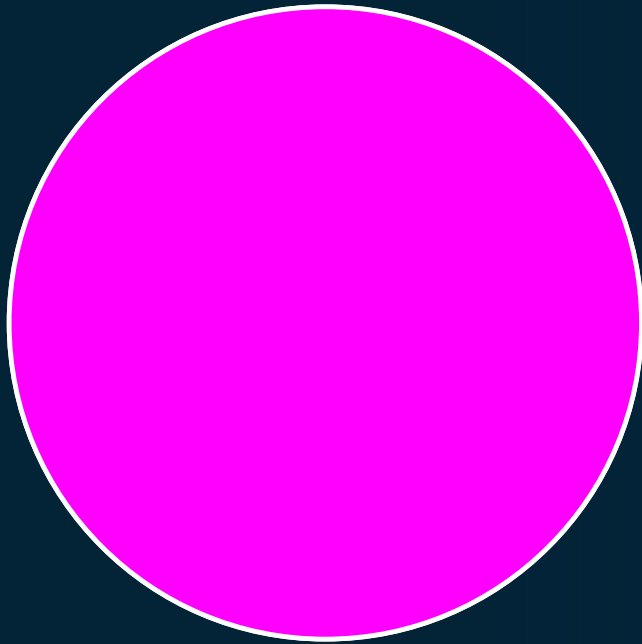


HUMAN REVIEW

Technical translation accuracy

Deepfakes, Impersonation & Social Engineering

Chapter 10 · Episode 08 · Domain 3.2 — AI as an Offensive Weapon



Learning Objectives

1. Recognize the three deepfake modalities and an attack use case for each
2. Explain how AI collapses the scale-vs-personalization trade-off
3. Choose out-of-band verification as the primary defense

Three Deepfake Modalities

AUDIO

Voice clone from seconds
CEO wire-transfer fraud

VIDEO

Fabricated exec statements
Authorize in a video call

IMAGE

Synthetic photos
Identity & document fraud

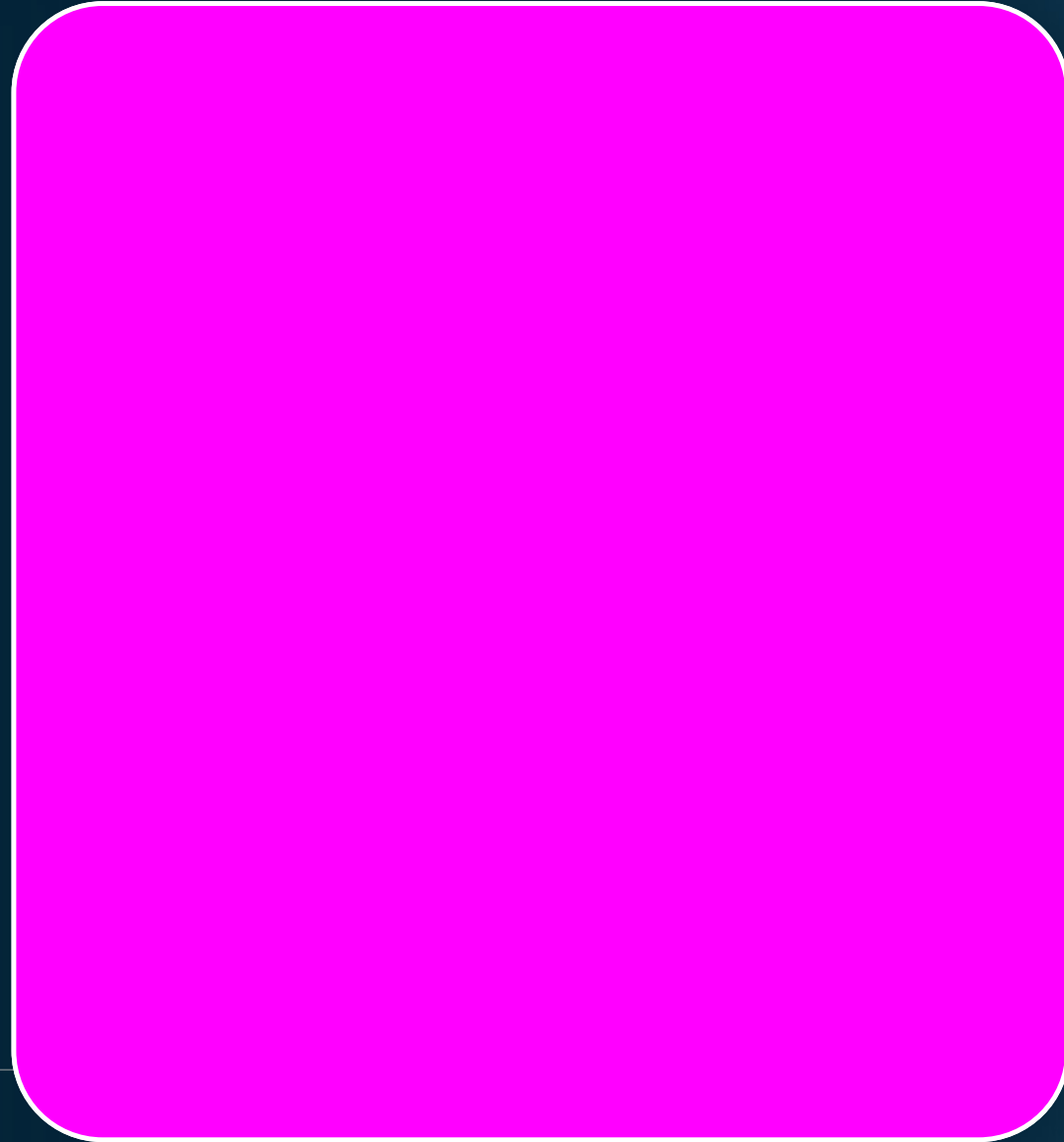
AI-Enhanced Social Engineering

Spear phishing at scale + personalized

Real-time voice conversion on calls

Fabricated profiles & backstories

Scale + personalization + automation



Detection Indicators

AUDIO

Unnatural prosody
Latency artifacts

VIDEO

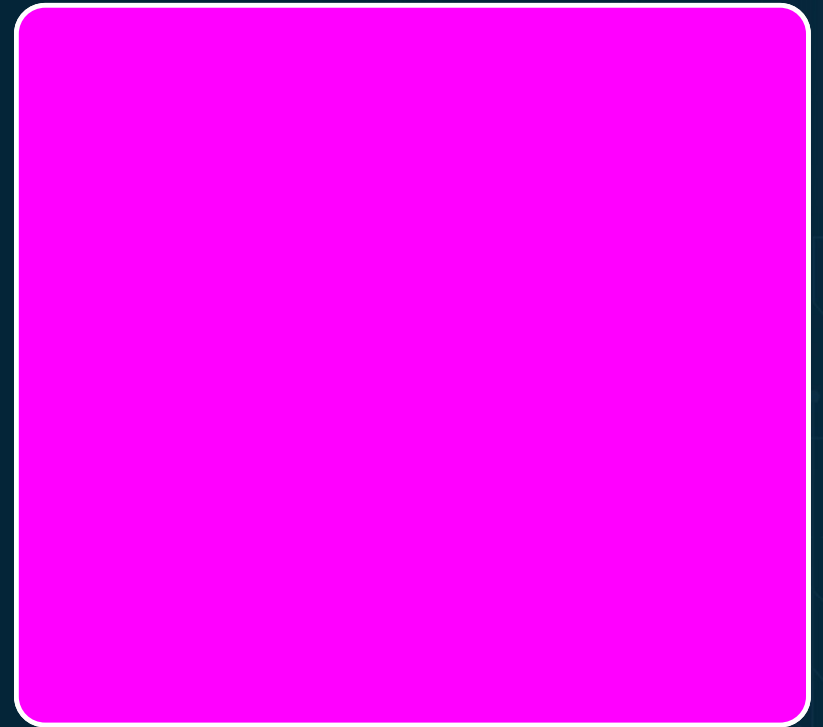
Bad lighting & blinking
Lip-sync drift

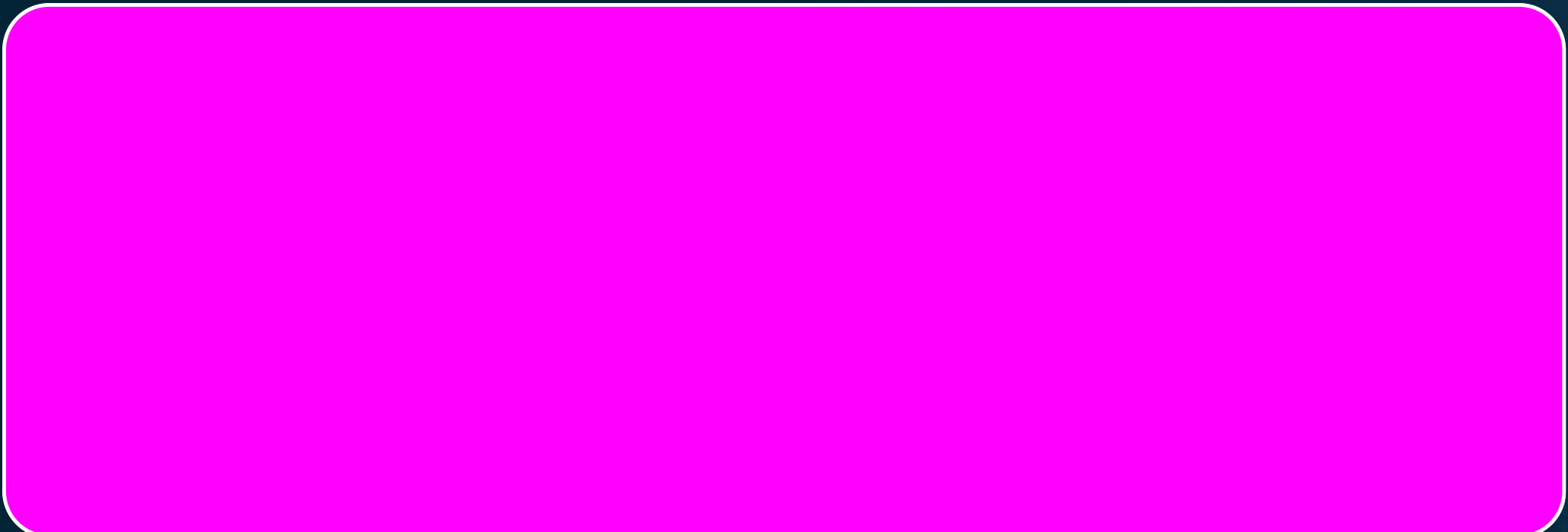
WRITTEN

Stylistically uniform
No personal detail

Defense: Out-of-Band Verification

Mandatory out-of-band confirmation
For financial / credential / sensitive acts
Process controls > technical detection
No detector is reliable in isolation





Demo: Deepfake Indicator Analysis

Audio, video & written AI-content detection + out-of-band verification workflow
& defensive governance audit

Exam Tips



3 MODALITIES

Audio, video, image



SCALE + QUALITY

AI removes the trade-off



CEO WIRE FRAUD

Canonical audio example

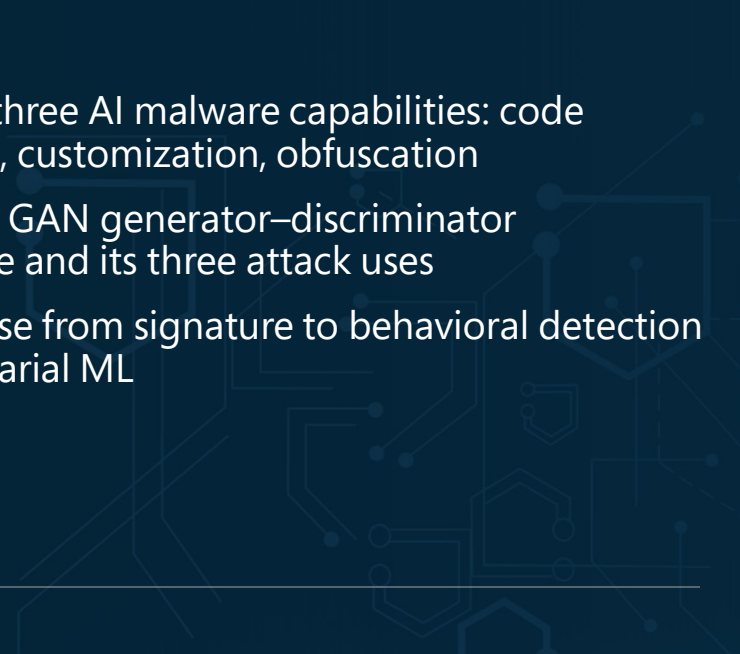
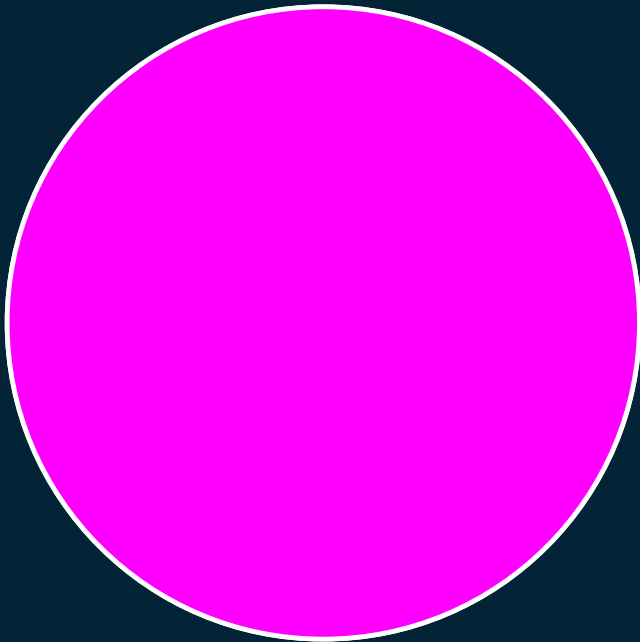


OUT-OF-BAND

The exam answer for defense

AI-Generated Malware & Payloads

Chapter 10 · Episode 09 · Domain 3.2 — Offensive AI Against Systems



Learning Objectives

1. Name the three AI malware capabilities: code generation, customization, obfuscation
2. Explain the GAN generator–discriminator architecture and its three attack uses
3. Shift defense from signature to behavioral detection and adversarial ML

AI Malware Capabilities

CODE GEN

Jailbroken exploit code
Accelerates low-skill attackers

CUSTOMIZATION

Target-specific variants
Adjust to OS & tooling

OBFUSCATION

Hundreds of variants
Overwhelms signatures

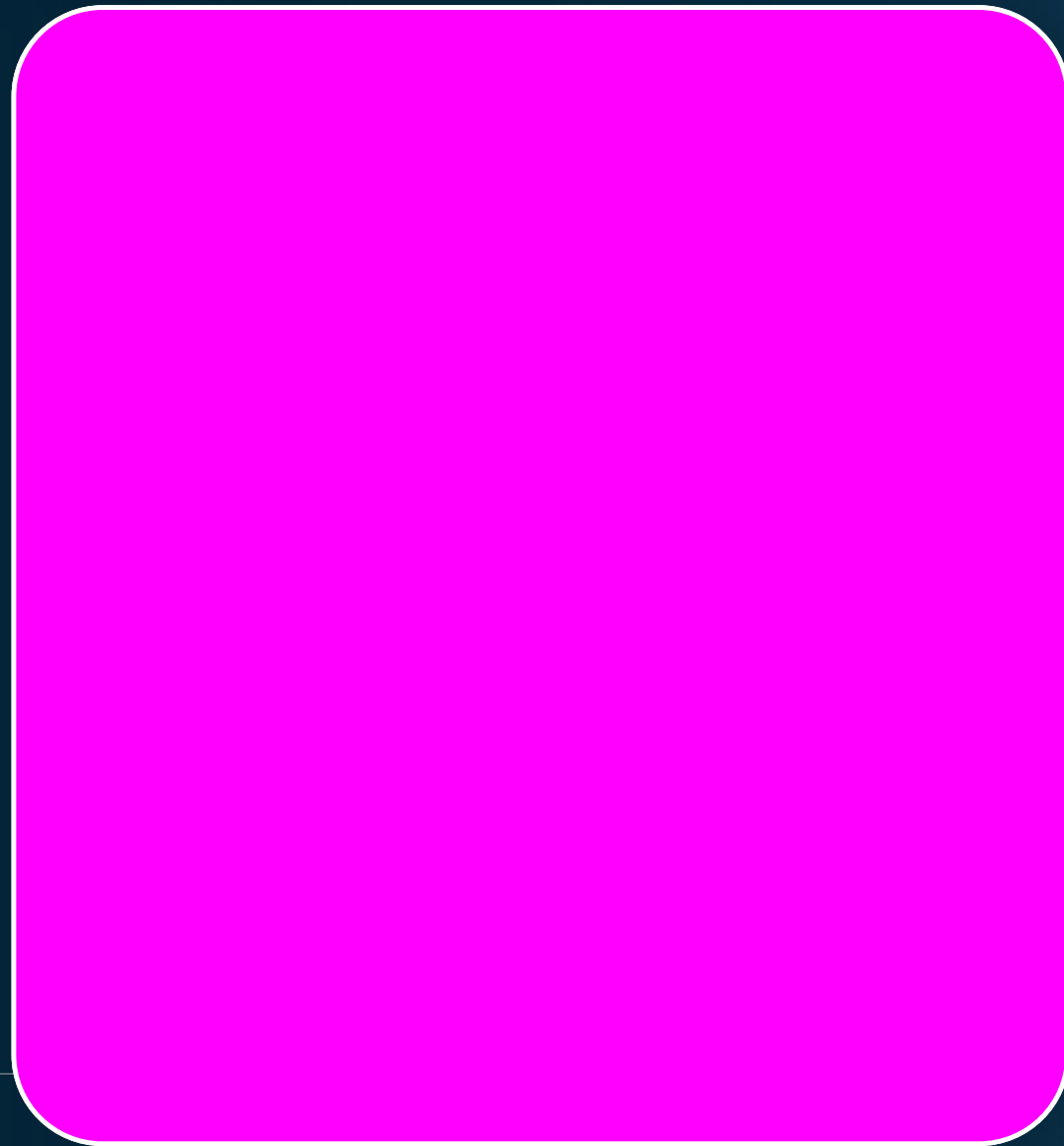
GANs: Generator vs Discriminator

Two networks compete → realistic output

Adversarial examples fool detectors

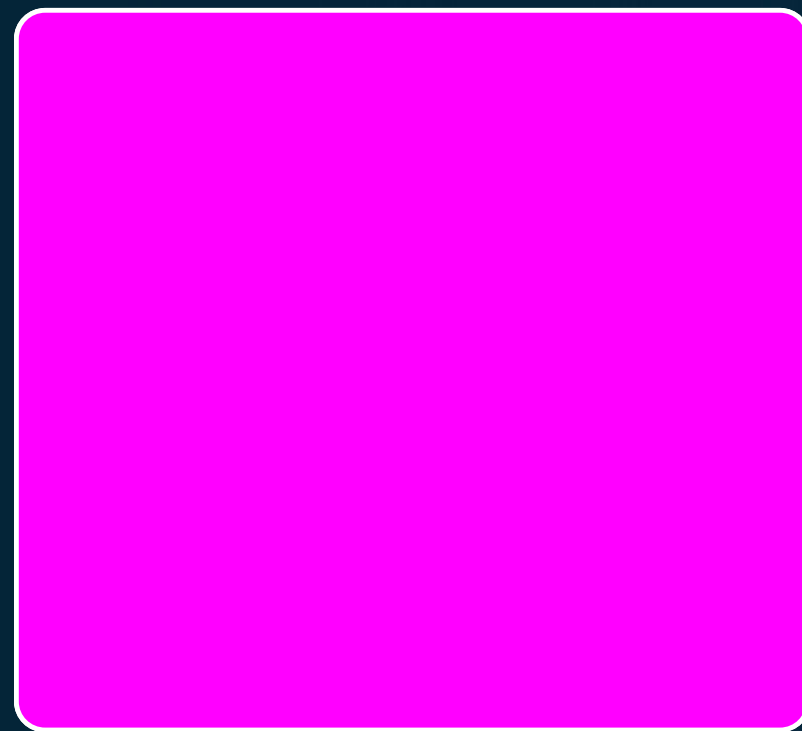
Synthetic training data for attacks

Evade behavioral detection



Automated Attack Operations

- AI fuzzing & vuln discovery
- AI-driven lateral movement
- Autonomous orchestration (emerging)
- Compresses the attack timeline



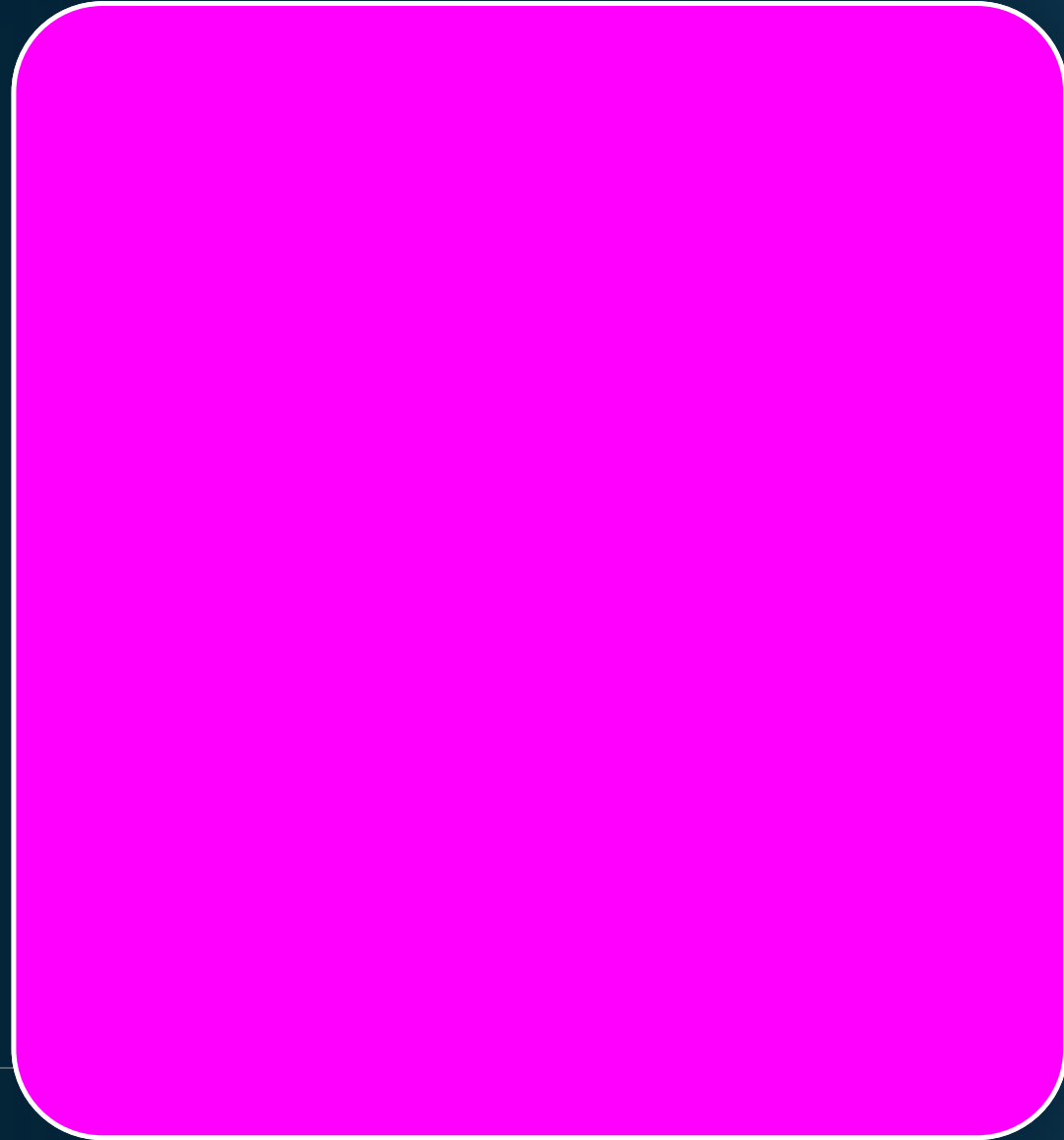
Defense: Behavioral over Signature

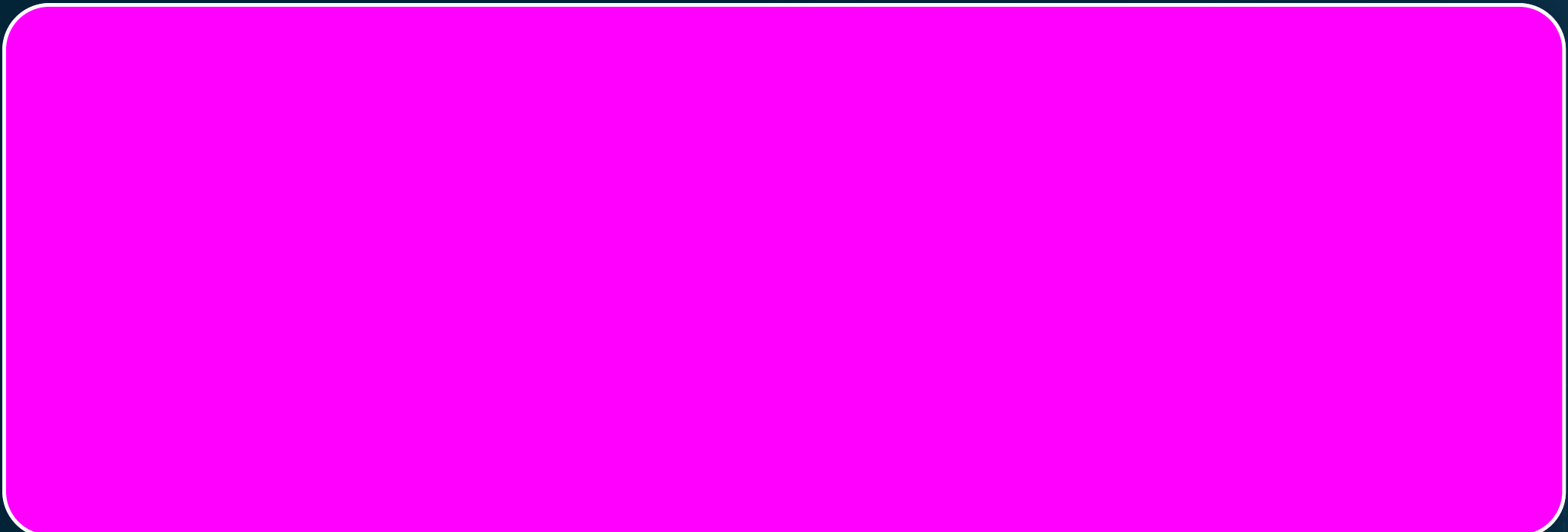
Signature-only can't keep pace

Behavioral detection: what code does

AI-vs-AI detection of synthetic content

Adversarial ML hardens models





Demo: AI Malware & Adversarial Networks

Obfuscation variant generation, GAN adversarial-example evasion, behavioral vs signature detection & adversarial-ML hardening

Exam Tips



3 CAPABILITIES

Gen, customize, obfuscate



BEHAVIORAL

Over signature-only



GANs

Generator vs discriminator

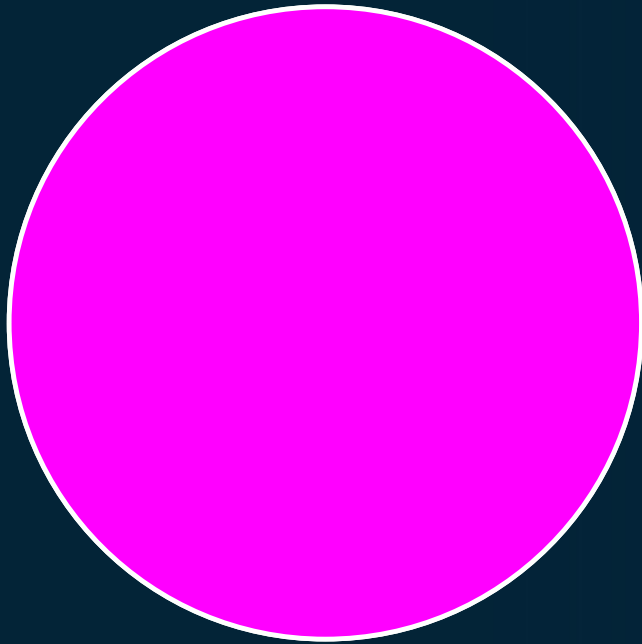


TIMELINE

Compressed → speed matters

Reconnaissance & Automated Data Correlation

Chapter 10 · Episode 10 · Domain 3.2 — Mapping Targets at Machine Scale



Learning Objectives

1. Explain automated OSINT and the AI-specific power of cross-source correlation
2. Connect people-intelligence aggregation to spear phishing at scale
3. Apply the three defensive countermeasures

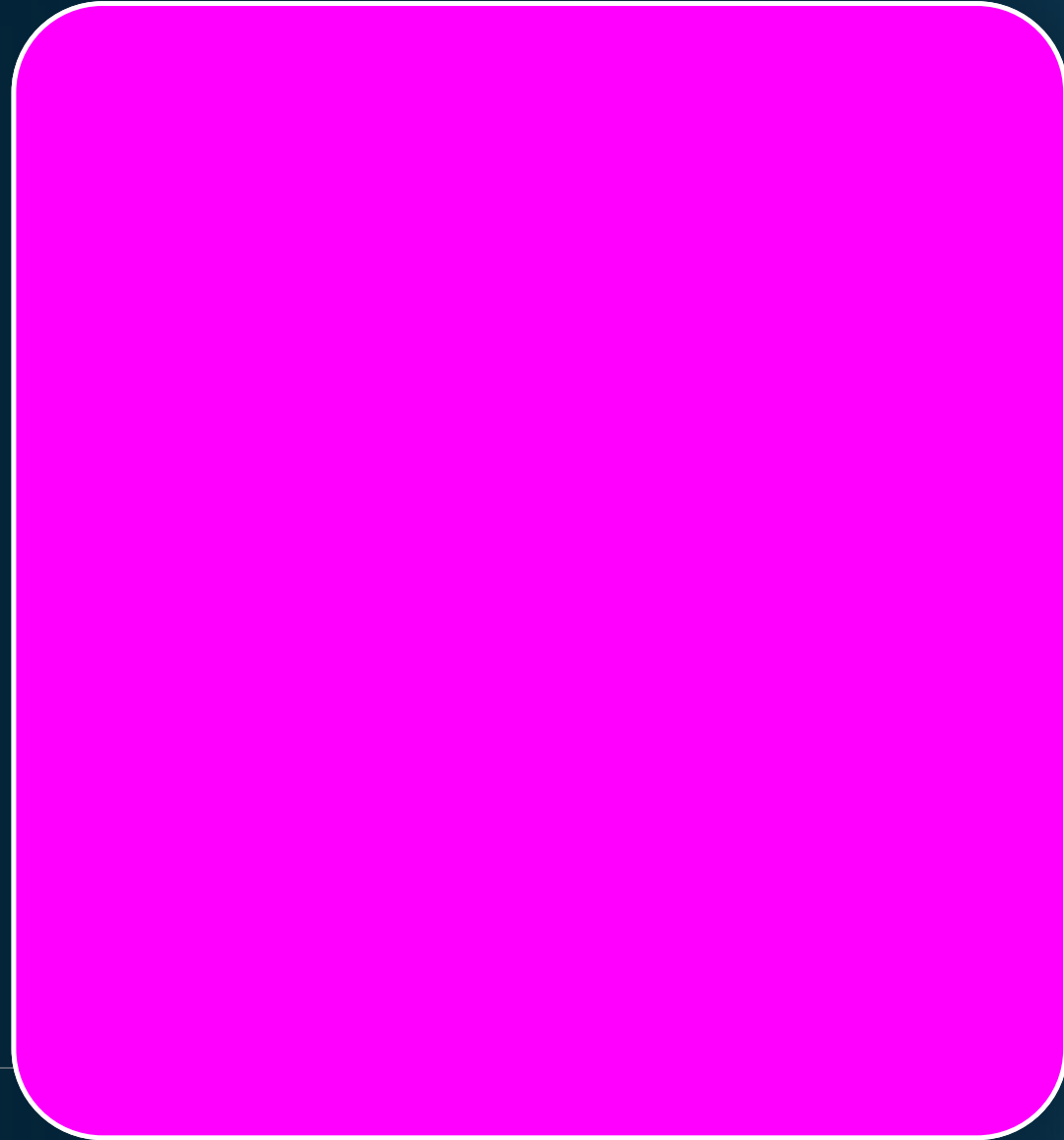
Automated OSINT + Correlation

Cert transparency, DNS, GitHub leaks

Job postings, LinkedIn, Shodan

AI correlates ACROSS sources

One unified picture → exploitation



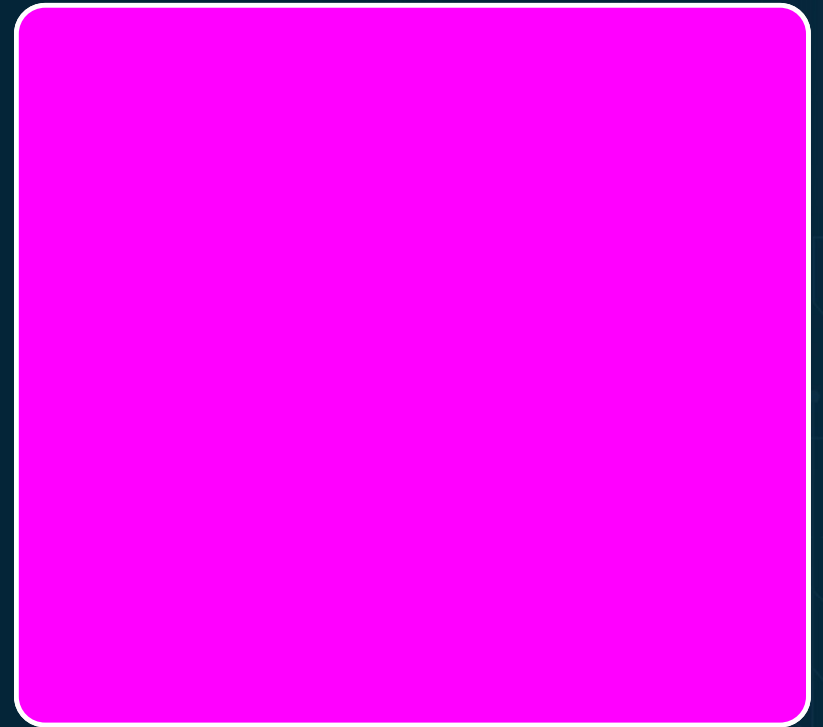
People Intel → Spear Phishing

Profile from LinkedIn, X, GitHub, breaches

Org graph: who has authority & access

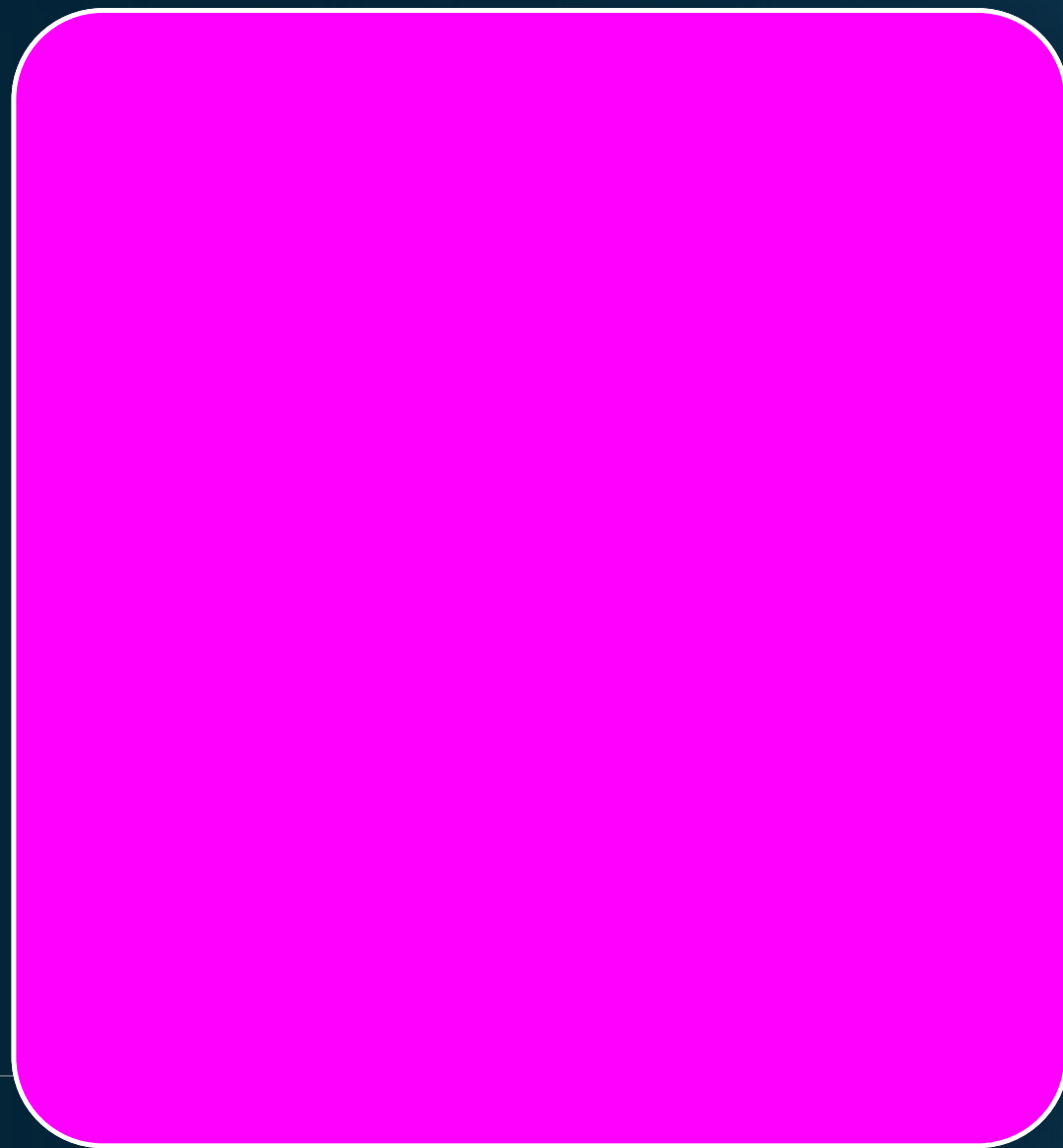
Personalized lures reference real detail

Recon feeds social engineering



Infra Recon → Exploit Roadmap

Correlate services with CVE databases
Asset enumeration → prioritized targets
Supply-chain mapping (vendors, MSPs)
Dark-web monitoring for leaked creds



Defensive Countermeasures

ATTACK SURFACE

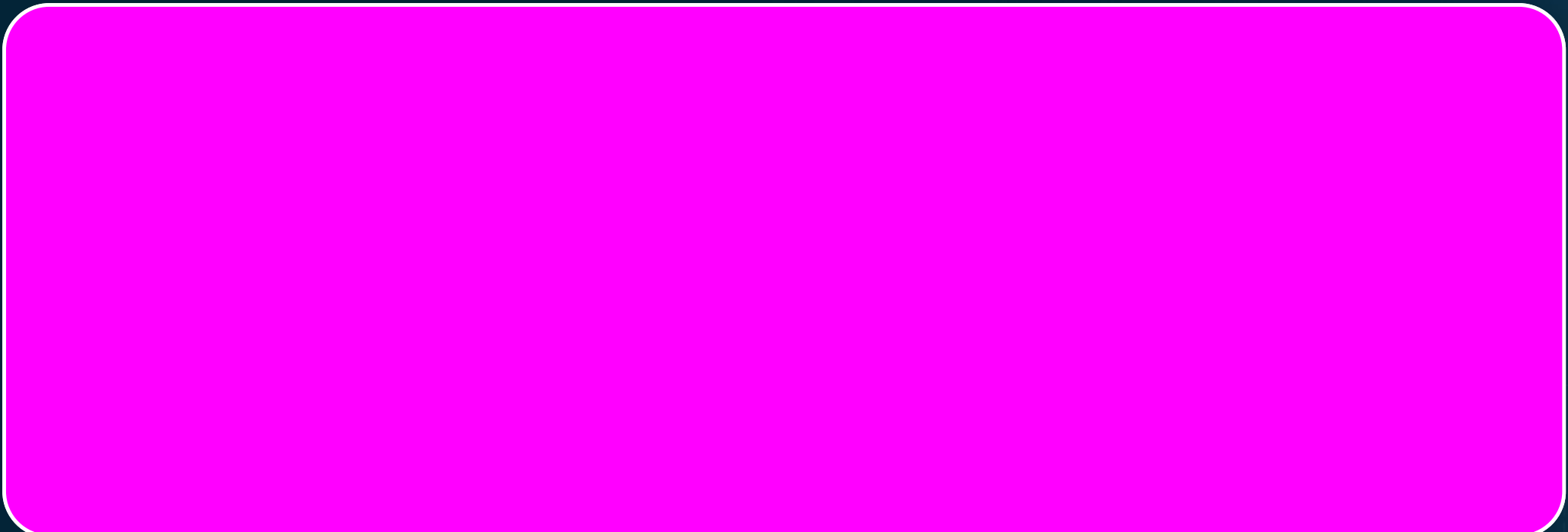
Offensive OSINT, inward
Outside-in assessment

INFO MINIMIZE

Cut public exposure
Watch repos & postings

DARK WEB

Early credential warning
Rotate before exploit



Demo: Recon & Data Correlation

OSINT aggregation across sources, cross-source correlation, people-intel for spear phishing & defensive attack-surface management

Exam Tips



CORRELATION

AI value = cross-source



INFRA RECON

Assets → exploit roadmap



PEOPLE INTEL

Enables spear phishing



DEFENSE

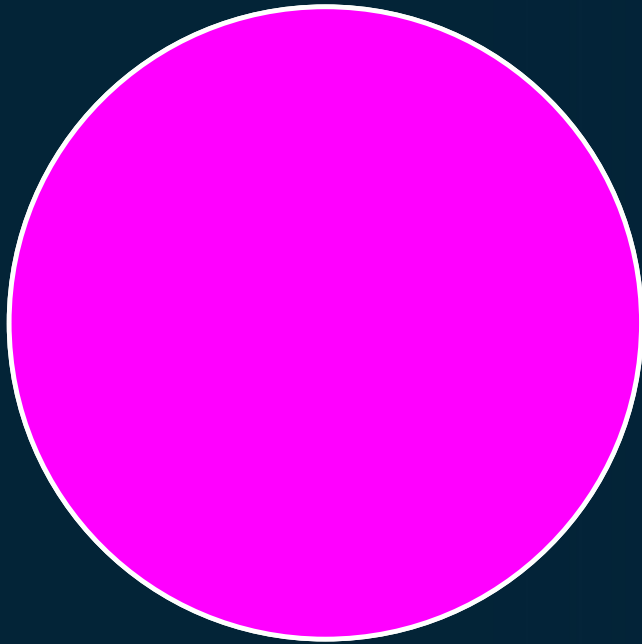
ASM, minimize, dark web



Honeypots & DDoS Automation

Chapter 10 · Episode 11 · Domain 3.2 — Adaptive Deception & Defense





Learning Objectives

1. Explain how AI honeypots evolve beyond static decoys
2. Recognize AI-enabled DDoS, including algorithmic-complexity attacks on AI endpoints
3. Match AI DDoS mitigation and honeypot governance to the exam

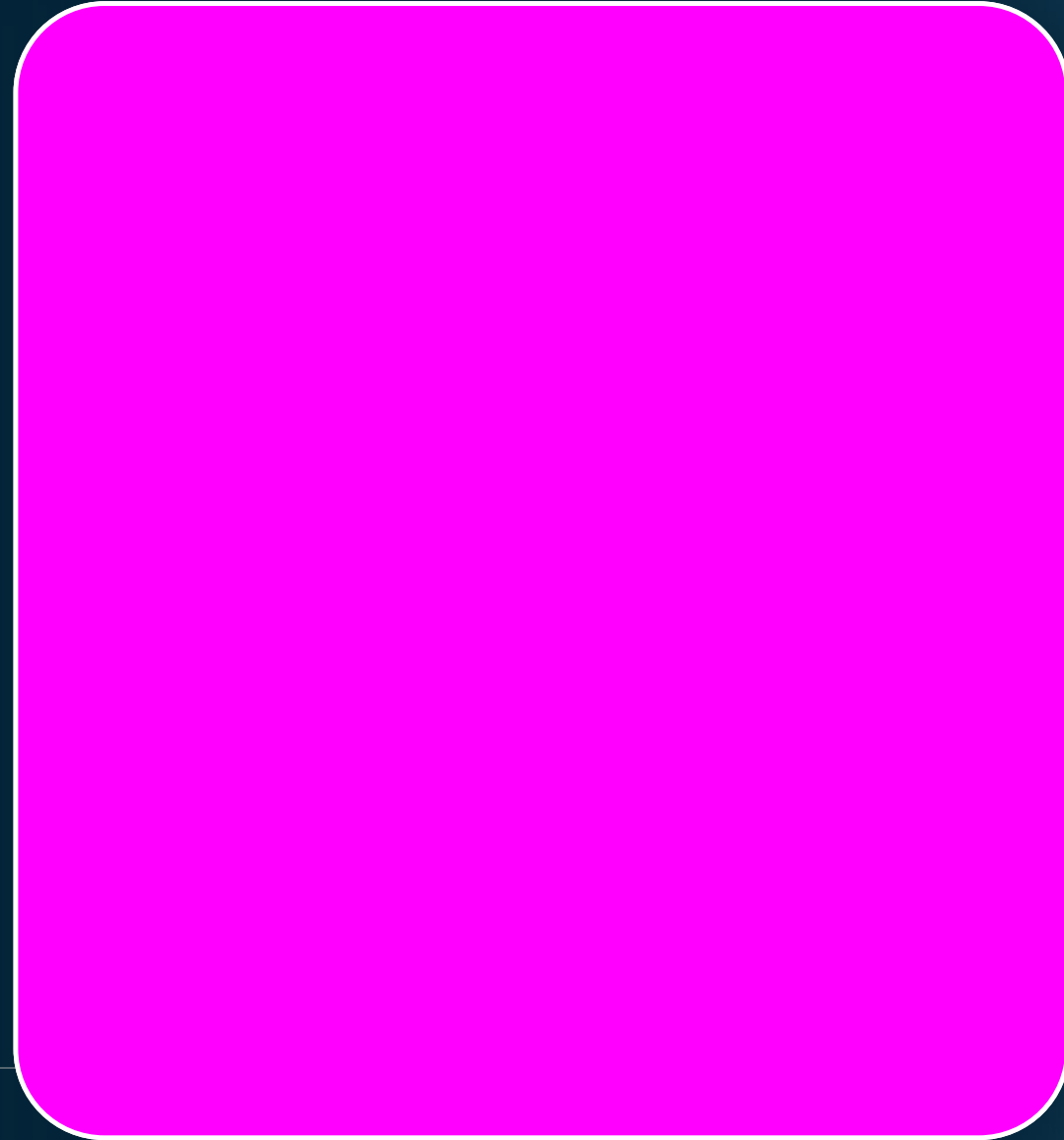
AI-Enhanced Honeypots

Dynamic environment simulation

Contextual responses to probes

Behavioral fingerprinting of attackers

High-fidelity TTP intelligence



AI-Enabled DDoS

ADAPTIVE PATTERNS

Vary signatures & sources

Evade static rate limiting

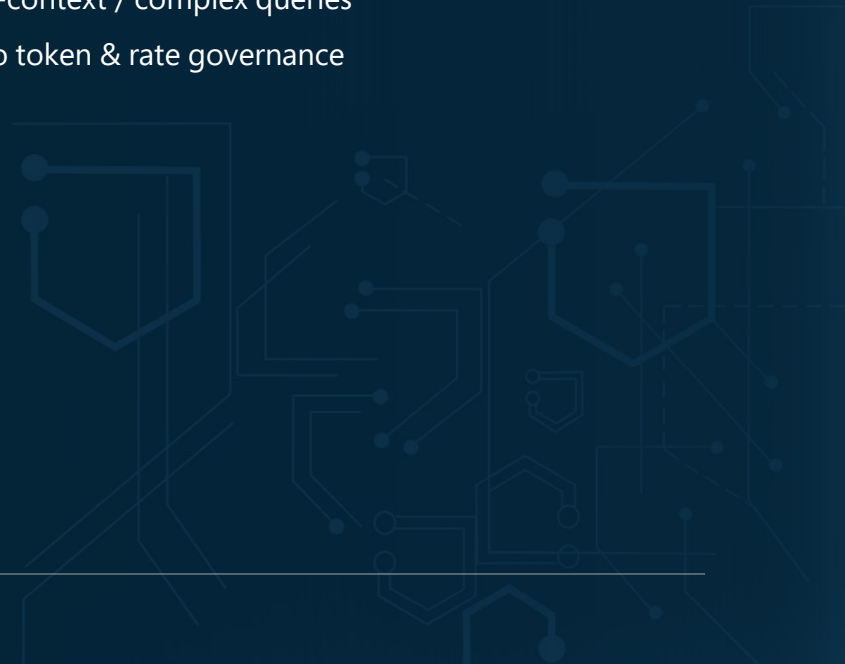
Mitigation adapts, so does attack

ALGORITHMIC COMPLEXITY

Target AI inference cost

Large-context / complex queries

Ties to token & rate governance



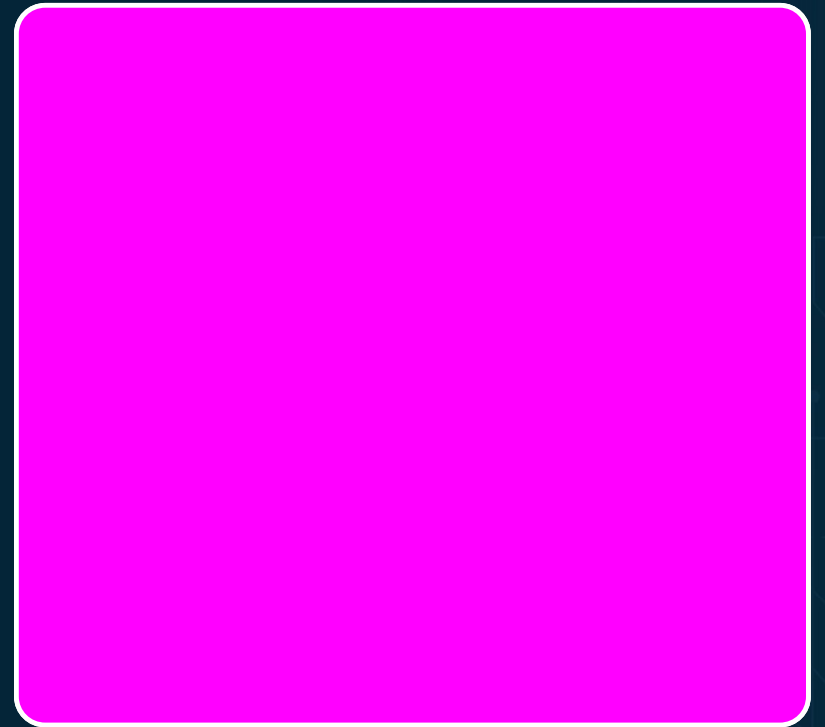
AI DDoS Mitigation

Behavioral traffic analysis

Learn legit timing, geo, sessions

Dynamic threshold adjustment

Static rules insufficient vs adaptive



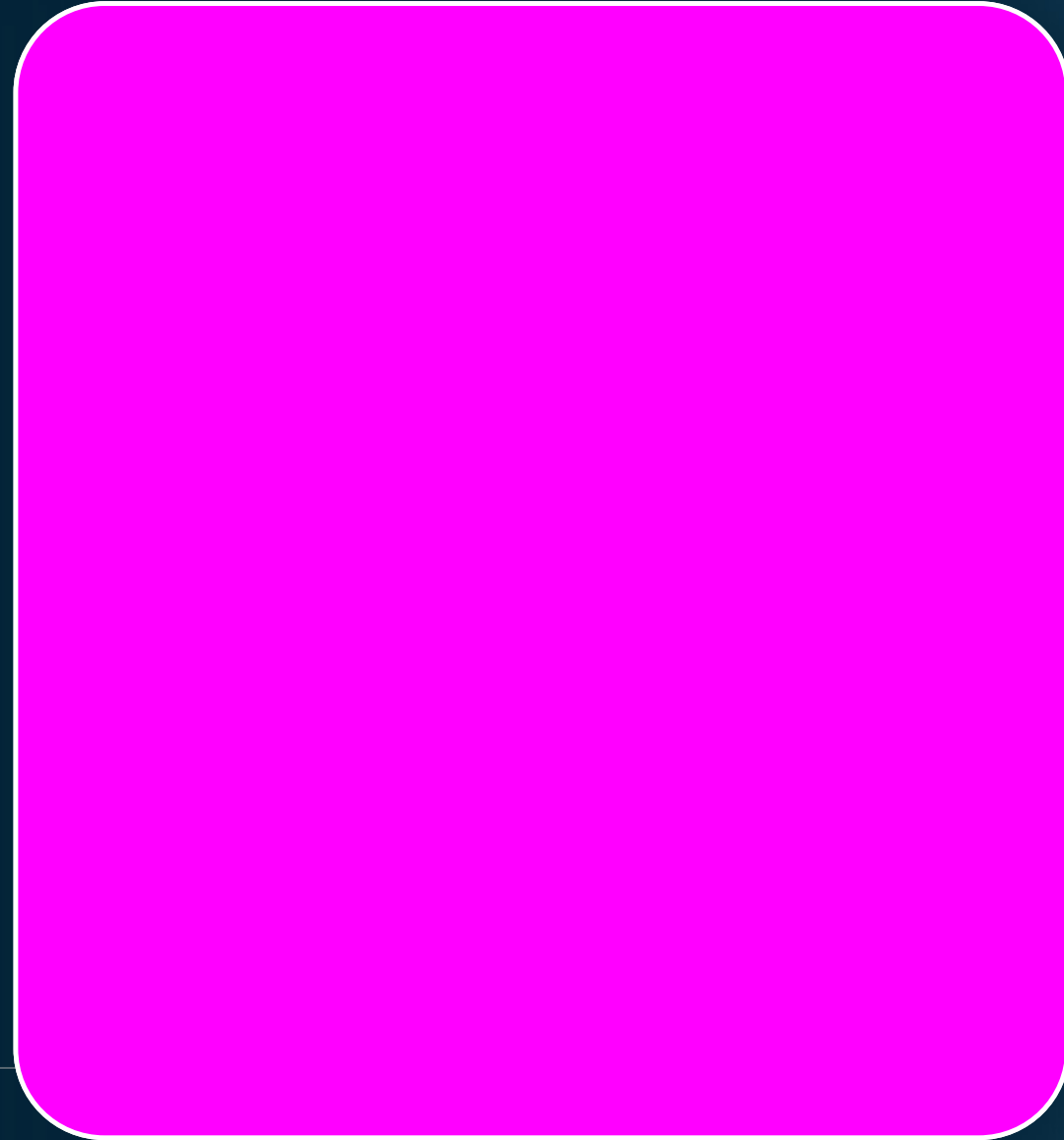
Governance for Both

Honeypot: legal authorization & jurisdiction

Honeypot data: privacy & disclosure

DDoS: false-positive rate governance

Share TTPs via ISACs responsibly



Demo: Honeypots & DDoS Automation

AI honeypot behavioral fingerprinting, algorithmic-complexity DoS detection, adaptive DDoS traffic analysis & governance checks

Exam Tips



AI HONEYPOTS

Dynamic deception, TTPs



AI MITIGATION

Behavioral + dynamic threshold



ALGO COMPLEXITY

Attack AI compute cost

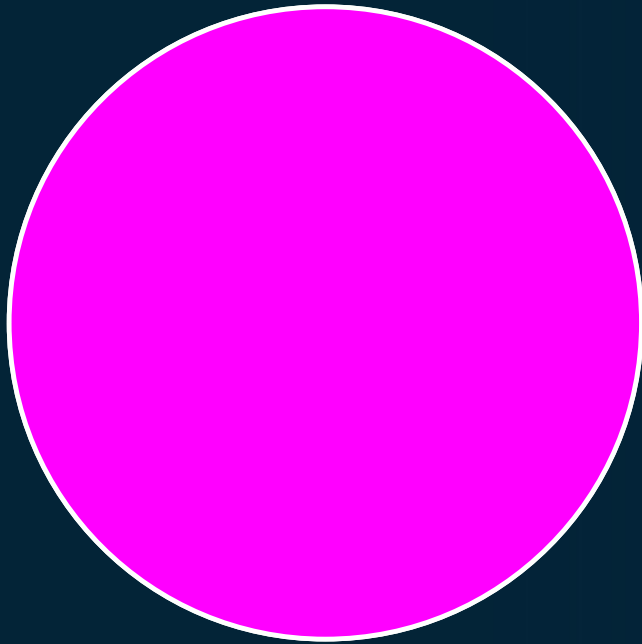


GOVERNANCE

Legal + false-positive

Low-Code & No-Code Automation

Chapter 10 · Episode 12 · Domain 3.3 — The Operational Delivery Layer



Learning Objectives

1. Distinguish low-code (visual + connectors) from no-code (natural language / wizard)
2. Name the four security-automation use cases and their workflow steps
3. Apply the three governance controls and flag shadow automation

Low-Code vs No-Code

LOW-CODE

Visual drag-and-drop builder
Pre-built connectors & logic blocks
For analysts / security engineers

NO-CODE

Natural language / wizard config
Zero technical development
For business security staff

Four Automation Use Cases



ALERT TRIAGE

Enrich, score, route



VULN MGMT

Scan, enrich, prioritize



PHISHING

URL detonation + ticket

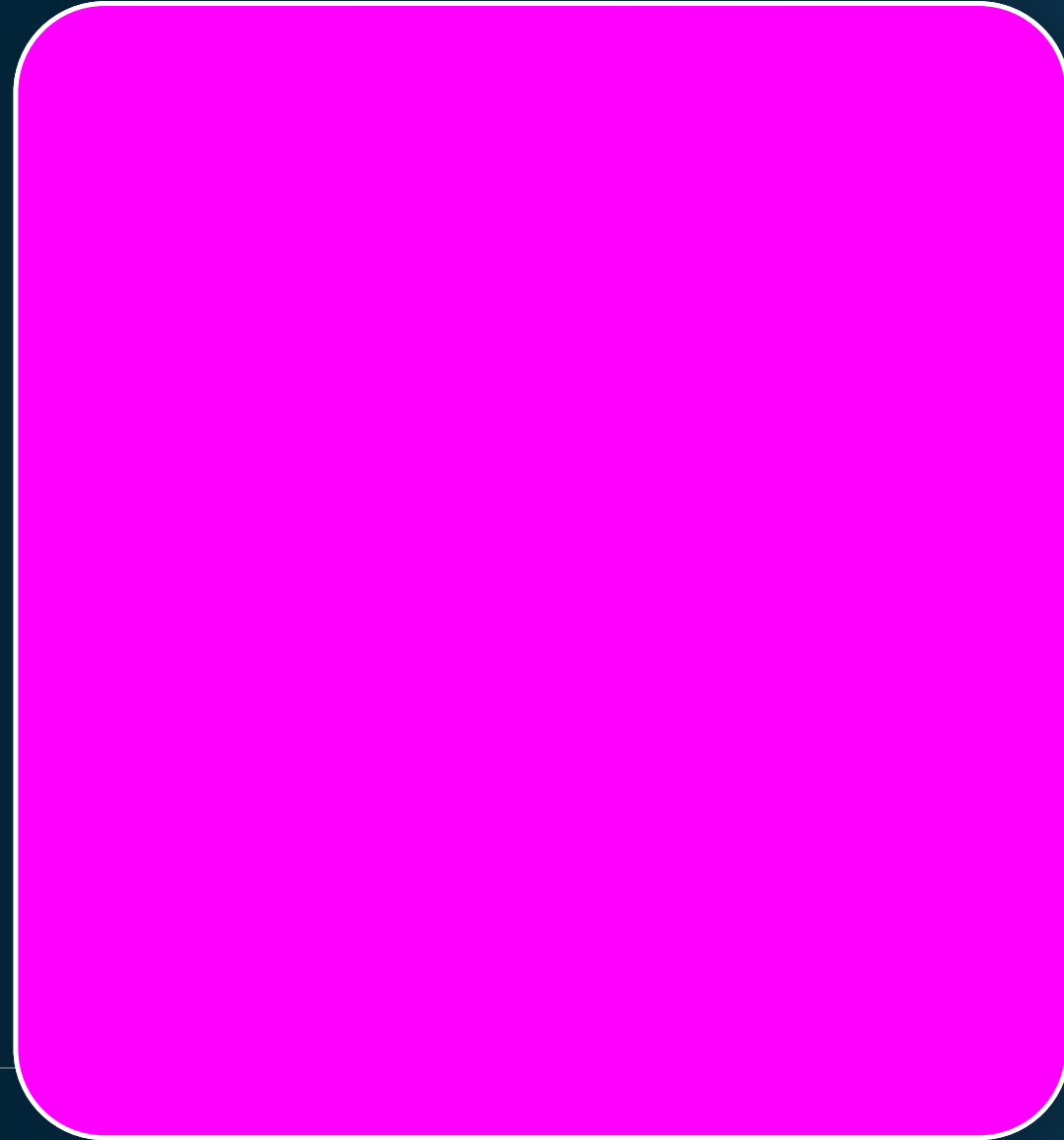


COMPLIANCE

Metrics + report gen

Risks of Easy Deployment

Governance gaps: no engineering review
Shadow automation (like shadow IT/AI)
Misconfig → data exposure / bad actions
Vendor lock-in & data residency



Governance Framework

CHANGE MGMT

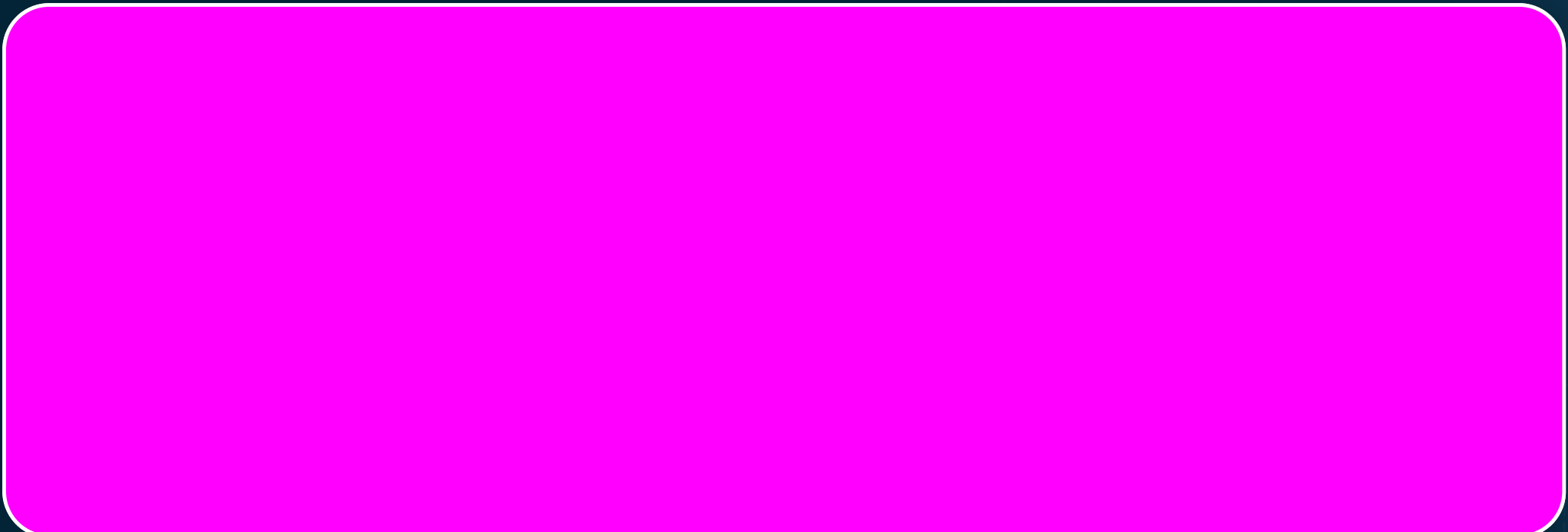
Approve before deploy
Mirror software SCM

LEAST PRIV

Scoped service accounts
No broad admin

AUDIT LOGS

Log every workflow action
Traceable identity



Demo: Low-Code / No-Code Automation

Four automation workflows, shadow-automation detection, governance audit
& AI-integrated workflow decision routing

Exam Tips



LOW vs NO-CODE

Visual vs NL/wizard



SHADOW AUTO

Unauthorized workflows



FOUR USE CASES

Triage, phishing,
vuln, compliance

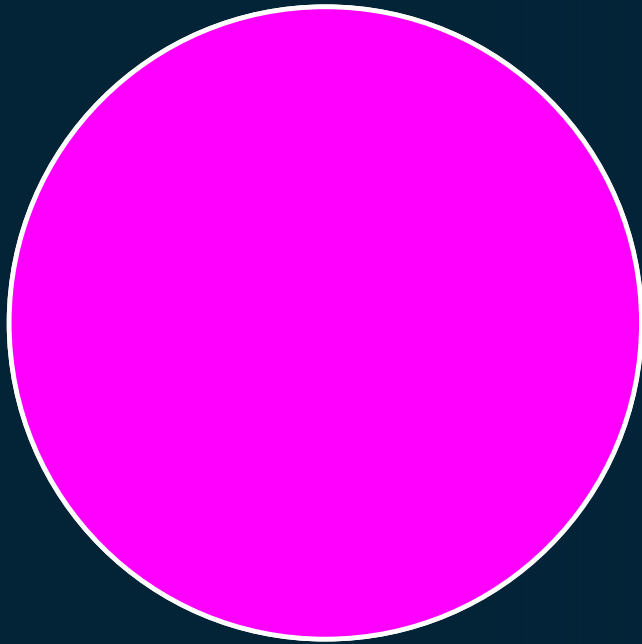


GOVERNANCE

Change, least-priv, audit

AI Agents & Orchestration

Chapter 10 · Episode 13 · Domain 3.3 — Autonomous Multi-Step Security Ops



Learning Objectives

1. Define agents: perceive, reason, plan, act with tools, iterate to a goal
2. Match the four agent use cases and the three orchestration patterns
3. Apply the full agent governance set: scope, HITL, logging, rollback

Four Agent Use Cases



INVESTIGATION

Full workflow, autonomous



MONITORING

Watch & escalate



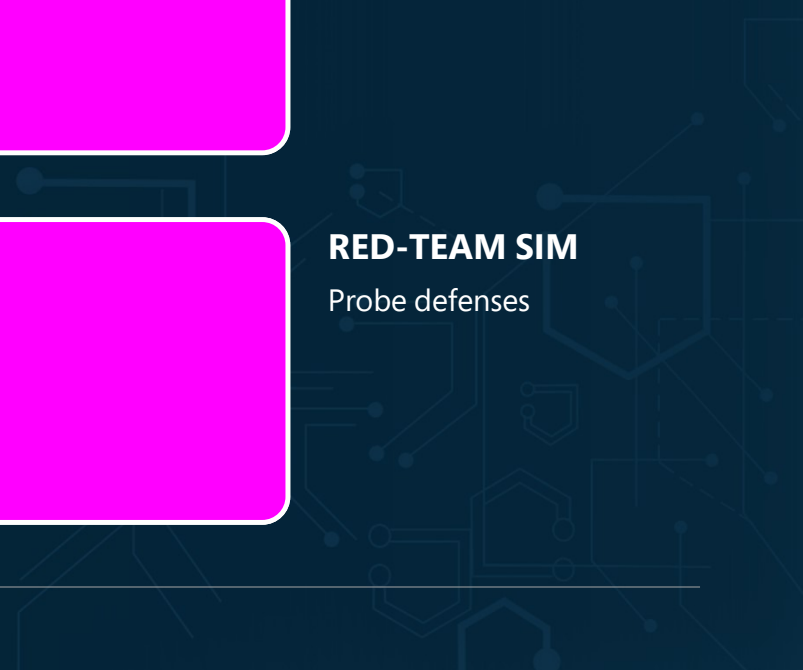
REMEDIATION

Isolate, block, revoke



RED-TEAM SIM

Probe defenses



Three Orchestration Patterns

SEQUENTIAL

Agents in order
Stage → stage handoff

PARALLEL

Run simultaneously
Aggregate results

HIERARCHICAL

Supervisor decomposes
Dispatches specialists

Agent Governance Set

ENFORCE

Scope containment (architected)

Human-in-the-loop on high impact

ACCOUNT

Comprehensive action logging

Rollback of incorrect actions

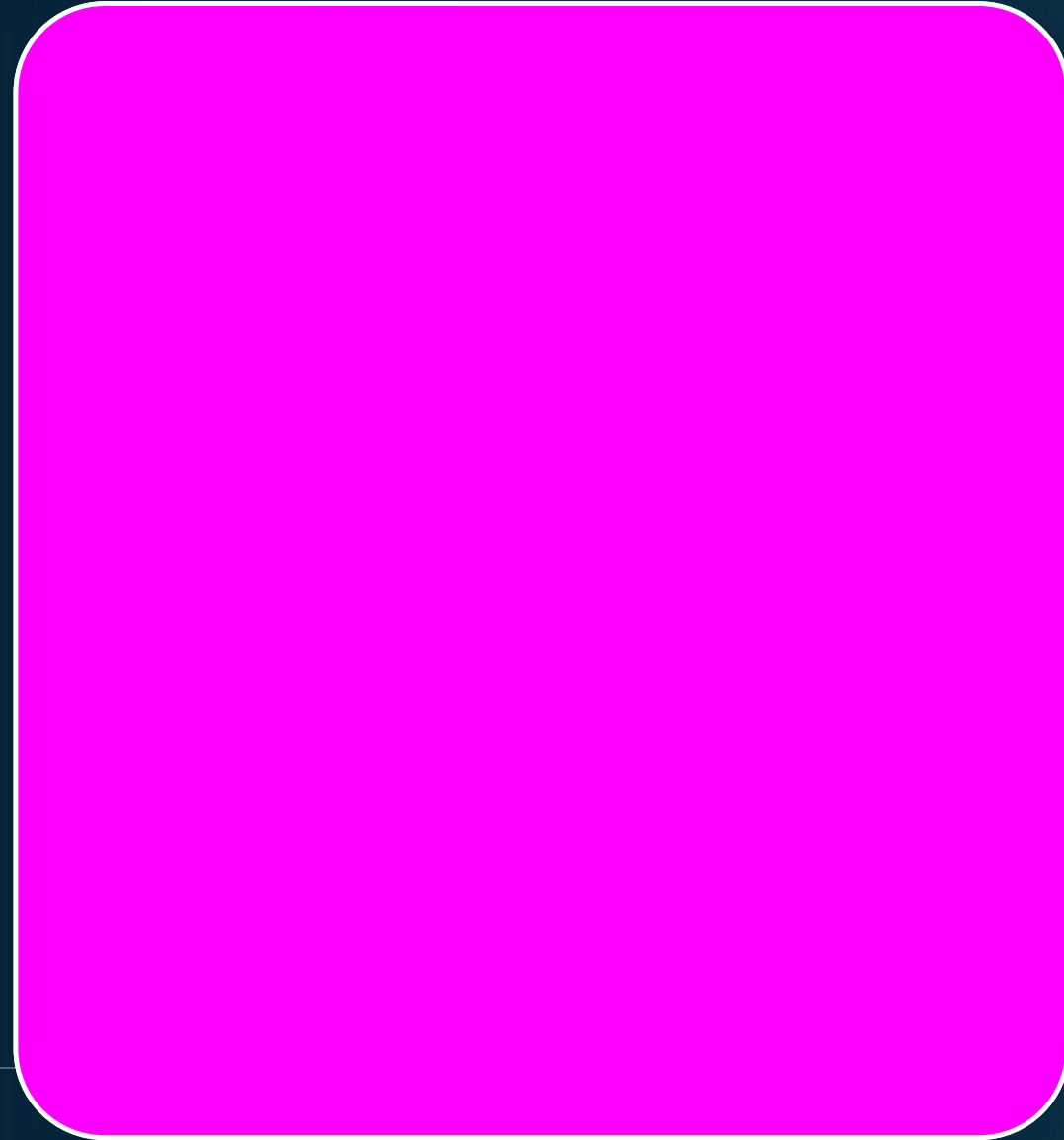
Autonomous Agent Risks

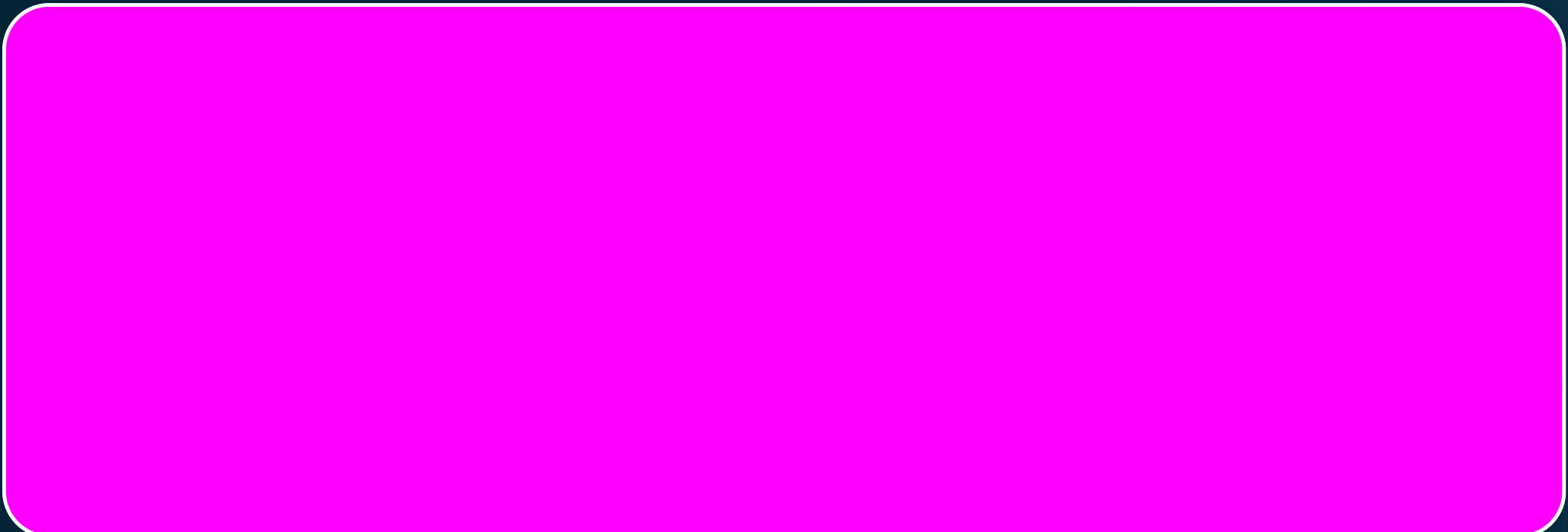
Goal misalignment → side effects

Prompt injection → operational action

Amplified: agents act, not just text

Agent chaining → failure cascade





Demo: Agents & Orchestration

All four use cases in all three patterns — human-in-the-loop, scope containment, reasoning-chain logging & prompt-injection detection

Exam Tips



4 USE CASES

Match to scenario



GOVERNANCE

Scope, HITL, log, rollback



3 PATTERNS

Sequential,
parallel, hierarchical

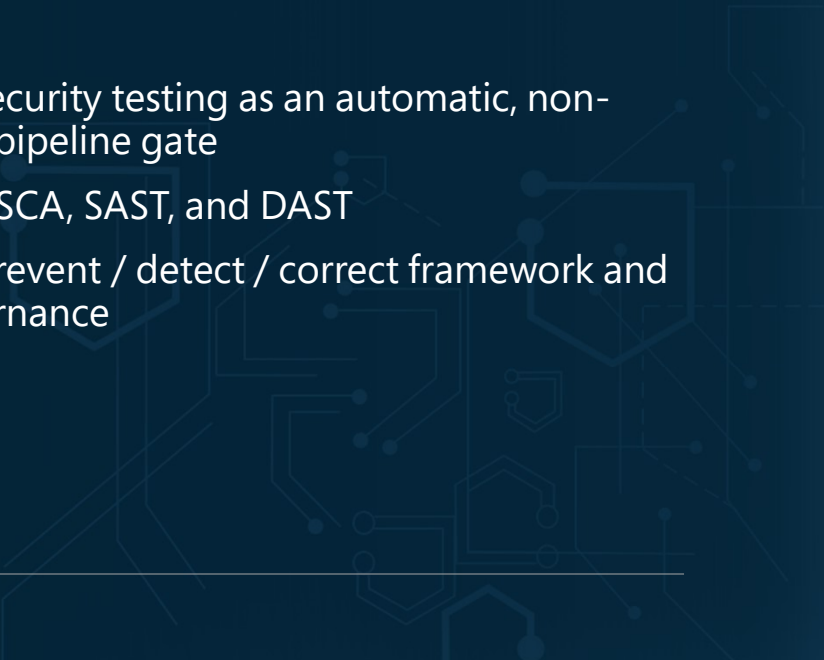
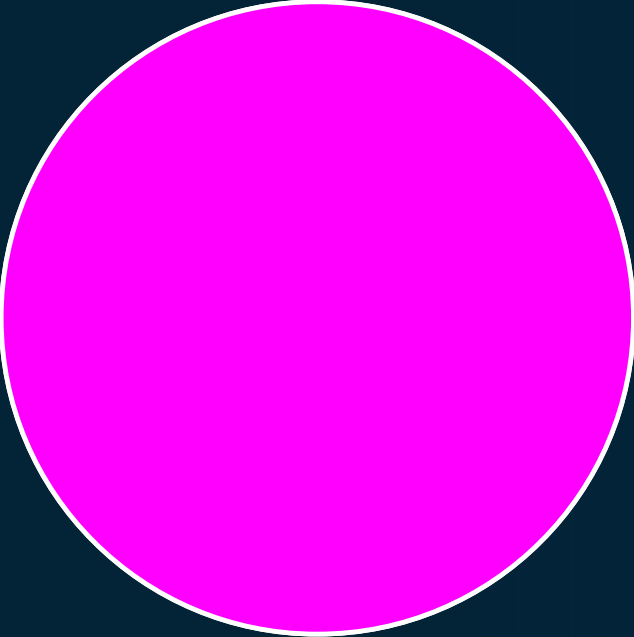


INJECTION

Amplified to action

CI/CD Integration with AI Security Testing

Chapter 10 · Episode 14 · Domain 3.3 — Security as a Non-Bypassable Gate



Learning Objectives

1. Embed AI security testing as an automatic, non-bypassable pipeline gate
2. Distinguish SCA, SAST, and DAST
3. Apply the prevent / detect / correct framework and CI/CD governance

Three AI Testing Types

SCA

Dependency analysis
Reachability priority

SAST

Static code analysis
Context cuts false positives

DAST

Dynamic runtime testing
Attack payloads & fuzzing

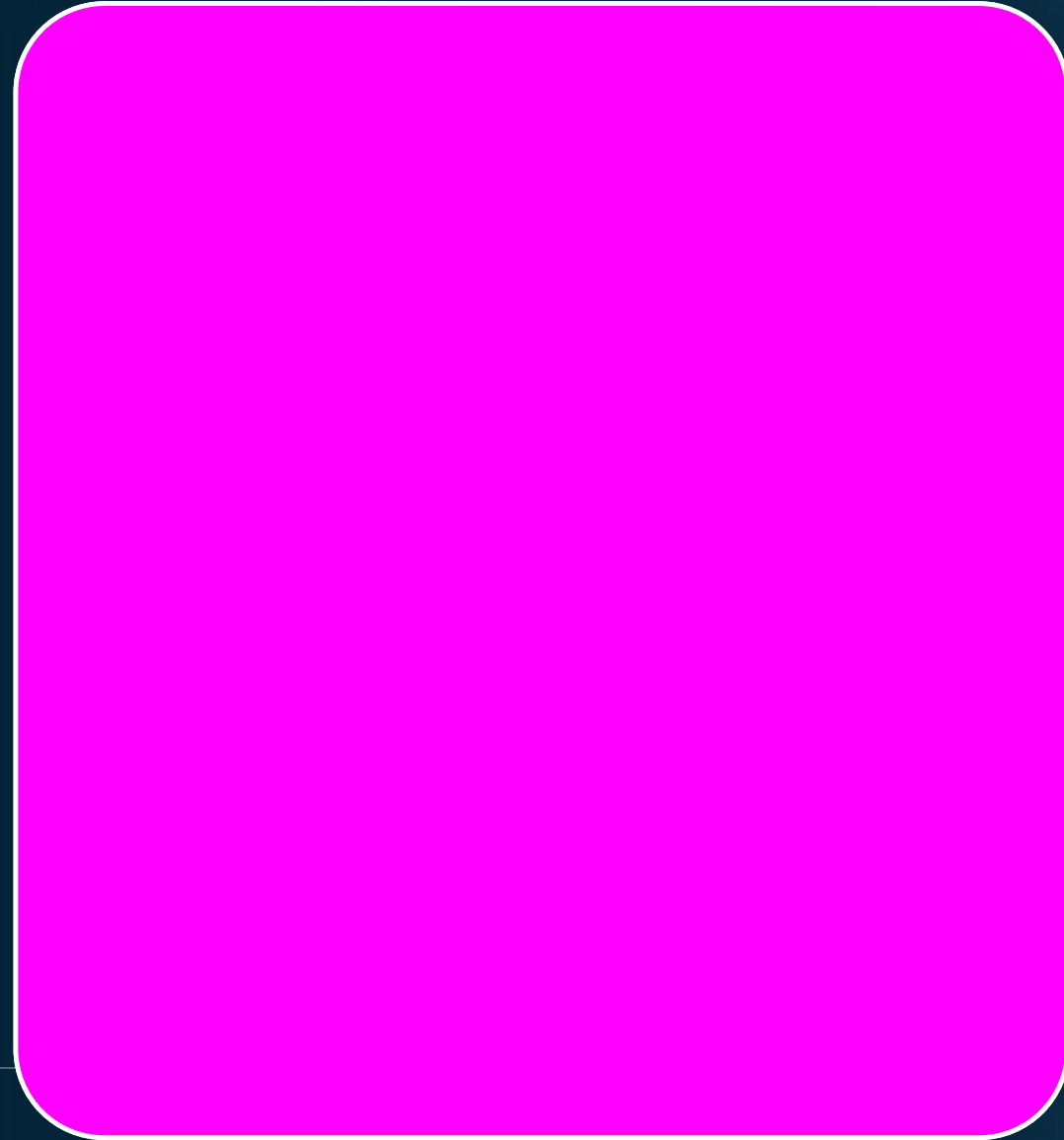
Pipeline Integration Points

Pre-commit hooks catch secrets

Security gates block deployment

Regression testing vs baseline

Gates make enforcement non-discretionary



Three-Part Security Posture

GATES

Preventative

Block on threshold

REGRESSION

Detective

Vs validated baseline

ROLLBACK

Corrective

Revert to known-good

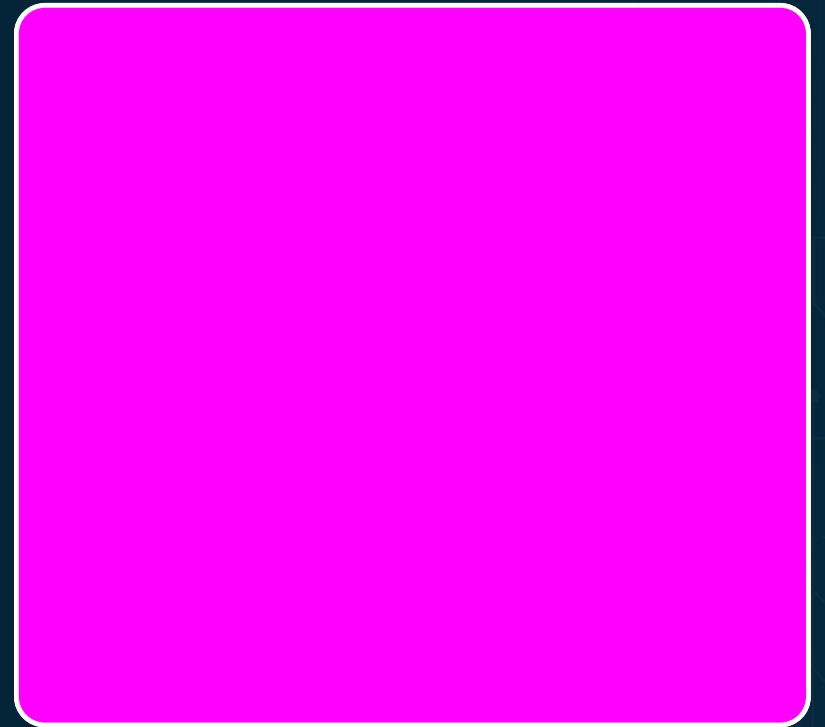
CI/CD Security Governance

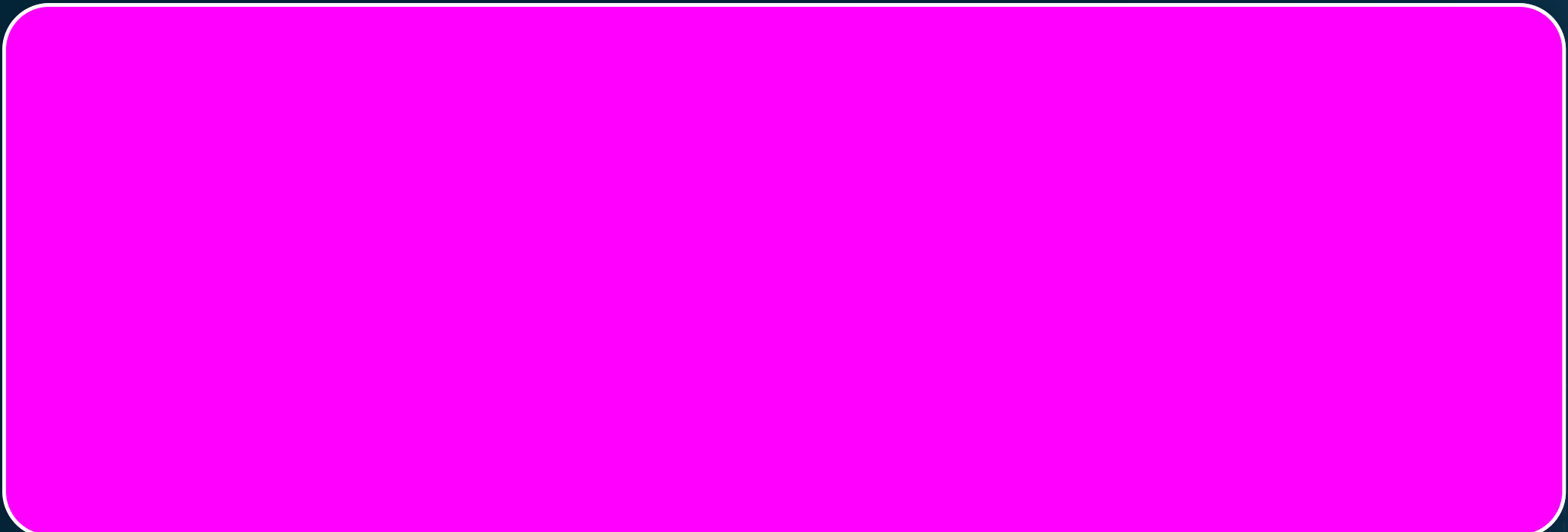
False-positive mgmt → avoid bypass

Coverage metrics on every commit

Separation of duties on gates

Devs can't disable their own gates





Demo: CI/CD AI Security Pipeline

Pre-commit hooks, SCA, SAST, DAST, security-gate enforcement, regression comparison & rollback decision logic

Exam Tips



SCA/SAST/DAST

Deps / static / dynamic



POSTURE

Prevent, detect, correct



3 POSITIONS

Pre-commit, gate,
post-deploy



SEP OF DUTIES

No self-disabling gates